



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل 7: الأمان في نظم التشغيل



دبلوم امن المعلومات

اسم المقرر:	مفاهيم نظم التشغيل
رمز المقرر:	ISE122
الموضوع:	الفصل 7: الأمان في نظم التشغيل



يميز بين المصادقة والتفويض والتحكم في الوصول.

يشرح حماية المستخدمين والموارد في نظام التشغيل. 

يطبق مصفوفة وصول مبسطة على ملفات وموارد حساسة. 

يقارن نماذج DAC و MAC و RBAC في سيناريو مؤسسي. 

يحلل أثراً أمنياً لصلاحيات مفرطة ويقترح معالجة. 



خريطة الفصل

ينتظم الفصل في أربعة محاور مترابطة:





- ◀ ينقسم الفصل إلى سبع وحدات تعلم غير متزامنة مستقلة، مدة كل منها 60 دقيقة.
- ◀ يبدأ المتعلم كل وحدة بهدف محدد وتمهيد قصير، ثم يدرس محاورها ويؤدي نشاطاً تكوينياً واختباراً قصيراً من بنك الأسئلة، وينتهيها بخلاصة قابلة للمراجعة.



خطة الوحدات الزمنية (تابع)



الوحدة	الهدف والمحاور	التعلم والتطبيق والتقويم	الزمن
1	حماية الأصول والحسابات والمجموعات	دراسة الشرائح 5-9، نشاط جرد الأصول، اختبار قصير، خلاصة	60 دقيقة
2	المصادقة والتفويض والسياسة	دراسة الشرائح 10-14، قراءة A1، نشاط قرار الوصول، اختبار قصير، خلاصة	60 دقيقة
3	الموضوع والكائن و ACL ومصفوفة الوصول	دراسة الشرائح 15-24، تطبيق النموذج A2، اختبار قصير، خلاصة	60 دقيقة
4	الملكية وأقل الامتيازات وفصل المهام	دراسة الشرائح 25-27، نشاط توزيع الأدوار، اختبار قصير، خلاصة	60 دقيقة



خطة الوحدات الزمنية (تابع)



الوحدة	الهدف والمحاور	التعلم والتطبيق والتقويم	الزمن
5	التدقيق وسجل النظام ومراجعة الصلاحيات	دراسة الشرائح 28-30 و 41-42، قراءة A3 و A4، اختبار قصير، خلاصة	60 دقيقة
6	نماذج DAC و MAC و RBAC والتسمية الأمنية	دراسة الشرائح 31-35، نشاط مقارنة النماذج، اختبار قصير، خلاصة	60 دقيقة
7	الامتيازات وحماية كلمة المرور و MFA والمشروع	دراسة الشرائح 36-47، نشاط قرار وقائي، اختبار قصير، مهمة المشروع وخلاصة	60 دقيقة

تتضمن الوحدات تطبيقات إلزامية على المستندات وسجلات الأحداث، ومهام تحليلية موجهة. يخصص في الوحدة السابعة 25 دقيقة لمرحلة المشروع التراكمي الخاصة بضبط حسابات الخدمة ومواردها الحساسة.

(Operating System Security) أمن نظام التشغيل

- ◀ أمن نظام التشغيل هو مجموعة ضوابط وممارسات تحمي موارد النظام وعملياته وبياناته من الاستخدام أو التغيير غير المصرح به.
- ◀ وظيفته حماية الأصول عبر إدارة الحسابات، وفرض قرارات الوصول، والتدقيق، وحماية معلومات التدقيق.
- ◀ **الوظيفة:** حماية الموارد والعمليات والبيانات.
- ◀ **المسؤوليات:** فرض الوصول، تنفيذ قرارات السماح والمنع، إدارة الحسابات، ضبط الهويات وحالاتها، تقليل الامتيازات، حصر الحقوق اللازمة، تسجيل أحداث الأمن، دعم المساءلة، حماية معلومات التدقيق، منع العبث بالسجلات.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-53 Rev. 5، عائلات AC و IA و AU.
- ◀ **الأجهزة:** نظام التشغيل، آليات الحسابات، ACL، سجل أحداث الأمن، أدوات المراجعة.
- ◀ **وحدة البيانات:** قرار سماح أو منع، سجل تدقيق، إعدادات حسابات وصلاحيات.
- ◀ **مثال:** تحمي الشركة ملفات النسخ الاحتياطي وسجلات المصادقة بتحديد أدوار وصلاحيات ومراجعات دورية.



أمن نظام التشغيل (Operating System Security) (الشكل)

SLIDE 5 · OPERATING SYSTEM SECURITY

أمن نظام التشغيل



الأجهزة والأدوات

- نظام التشغيل
- آليات الحسابات
- ACL
- سجل أحداث الأمن
- أدوات المراجعة

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- عائلات AC و IA و AU

الوظائف الرئيسية

- حماية الموارد والعمليات والبيانات
- فرض الوصول
- تنفيذ قرارات السماح والمنع
- إدارة الحسابات
- ضبط الهويات وحالاتها

تحمي الشركة ملفات النسخ الاحتياطي وسجلات المصادقة بتحديد أدوار وصلاحيات ومراجعات دورية

أمن نظام التشغيل هو مجموعة ضوابط وممارسات تحمي موارد النظام وعملياته وبياناته من الاستخدام أو التغيير غير المصرح به



- ◀ الأصل هو مورد أو كيان يحتاج إلى حماية داخل نظام التشغيل، مثل ملف أو مجلد أو طابعة أو مفتاح سجل أو كائن خدمة.
- ◀ وظيفته تحديد الشيء الذي يطبق عليه قرار الوصول أو الحماية، حتى لا تقتصر المراجعة على الحسابات وحدها.
- ◀ **الوظيفة:** تمثيل المورد الخاضع للحماية.
- ◀ **المسؤوليات:** تحديد حساسية المورد، تصنيف الحاجة للحماية، تعيين مالك، إسناد مسؤولية أولية، تحديد التصاريح، تقييد الأفعال المسموحة، ضبط التدقيق، تسجيل الوصول المهم، مراجعة الاستخدام، كشف الصلاحيات غير اللازمة.
- ◀ **البروتوكولات والمعايير:** AC-3، AU-2، AU-9 في NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** ملفات، مجلدات، طابعات، مفاتيح سجل، موارد شبكية، كائنات دليل.
- ◀ **وحدة البيانات:** كائن قابل للتأمين أو مورد محمي.
- ◀ **مثال:** يعد سجل التدقيق الأمني أصلاً عالي الحساسية لأن تعديله قد يضعف التحقيق في الأحداث.



SLIDE 6 · ASSET

الأصل



كائن قابل للتأمين أو مورد محمي

الأجهزة والأدوات

- ملفات
- مجلدات
- طابعات
- مفاتيح سجل
- موارد شبكية

البروتوكولات والمعايير

- AC-3
- AU-2
- NIST SP 800-53 Rev. 5 في AU-9

الوظائف الرئيسية

- تمثيل المورد الخاضع للحماية
- تحديد حساسية المورد
- تصنيف الحاجة للحماية
- تعيين مالك
- إسناد مسؤولية أولية

يعد سجل التدقيق الأمني أصلاً عالي الحساسية لأن تعديله قد يضعف التحقيق في الأحداث.

الأصل هو مورد أو كيان يحتاج إلى حماية داخل نظام التشغيل، مثل ملف أو مجلد أو طابعة أو مفتاح سجل أو كائن خدمة



- المستخدم هو هوية بشرية أو رقمية تطلب استخدام مورد في النظام.
- وظائفه تمثيل الجهة التي تطلب الوصول أو تنفيذ عملية على مورد، ولا تعني هذه الهوية أنها مخولة تلقائياً بكل الأفعال أو الموارد.
- الوظيفة:** تمثيل طالب الوصول إلى المورد.
- المسؤوليات:** المصادقة، إثبات الهوية للنظام، الالتزام بالصلاحيات، تنفيذ الأفعال المخولة فقط، استخدام الحساب المخصص، تجنب الحسابات المشتركة، عدم مشاركة بيانات الدخول، حماية وسيلة التحقق، مراجعة الوصول، تحديثه عند تغير الدور.
- البروتوكولات والمعايير:** إدارة الحسابات، الهوية والمصادقة، التحكم في الوصول في NIST SP 800-53 Rev. 5.
- الأجهزة:** حساب مستخدم، معرف أمني SID في Windows، عضوية مجموعة، دور RBAC.
- وحدة البيانات:** هوية أو حساب أو تعيين دور.
- مثال:** يستخدم موظف التسجيل حساباً قياسياً للوصول إلى ملفات مهامه فقط.



المستخدم (User) (الشكل)

SLIDE 7 · USER

المستخدم

المستخدم. هو هوية بشرية أو رقمية تطلب استخدام مورد في النظام. وظيفته تمثيل الجهة التي **تطلب الوصول** أو تنفذ عملية على مورد، ولا تعني هذه الهوية أنها مخولة تلقائياً بكل الأفعال أو الموارد.



هوية أو حساب أو تعيين دور.

الأجهزة والأدوات

- حساب مستخدم
- معرف أمني SID في Windows
- عضوية مجموعة
- دور RBAC

البروتوكولات والمعايير

- إدارة الحسابات
- الهوية والمصادقة
- التحكم في الوصول في
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- تمثيل طالب الوصول إلى المورد
- المصادقة
- إثبات الهوية للنظام
- الالتزام بالصلاحيات
- تنفيذ الأفعال المخولة فقط

يستخدم موظف التسجيل حساباً قياسياً للوصول إلى ملفات مهامه فقط.

المستخدم هو هوية بشرية أو رقمية تطلب استخدام مورد في النظام.



(Account) الحساب

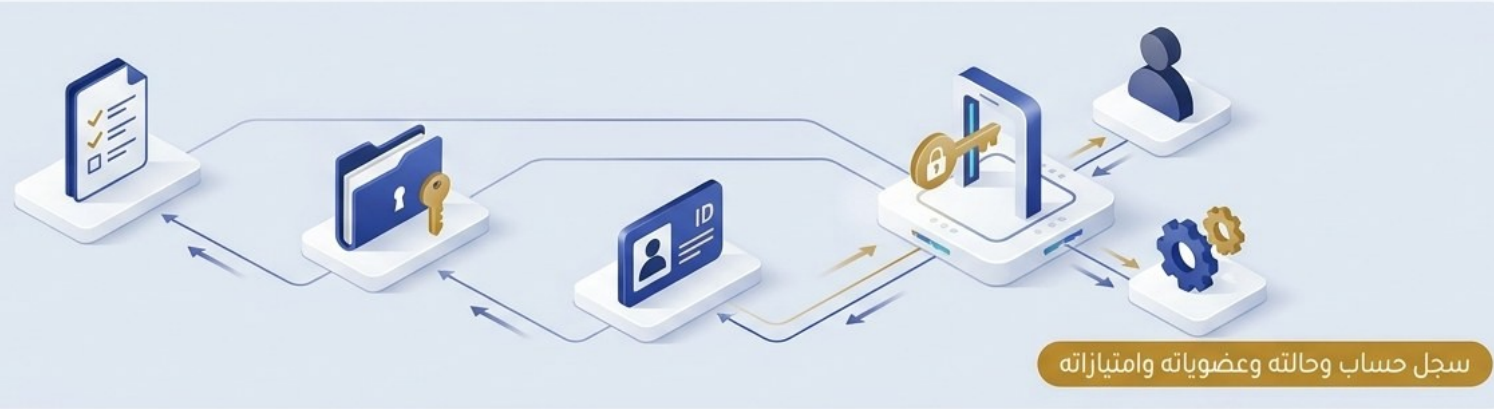
- ◀ الحساب هو تمثيل نظامي لهوية يتيح للنظام إدارة المصادقة والتصاريح وسلوك الاستخدام.
- ◀ وظيفته ربط المستخدم أو الخدمة بمعرف وصلاحيات وسياسات وصول محددة، بحيث يمكن مراجعة حالته وعضوياته وامتيازاته.
- ◀ **الوظيفة:** ربط الهوية بسياسات وصول محددة.
- ◀ **المسؤوليات:** الإنشاء، توفير هوية نظامية، المراجعة، التحقق من الحاجة المستمرة، التعطيل عند الحاجة، إيقاف الحسابات غير اللازمة، ضبط الحسابات المؤقتة، تحديد مدة استخدامها، منع الحسابات غير المصرح بها، تقليل مخاطر الوصول، تسجيل الأحداث، دعم مراجعة النشاط.
- ▶ **البروتوكولات والمعايير:** AC-2 Account Management في NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** مدير الحسابات، معرفات SID، مجموعات محلية أو مركزية، سجل أحداث الأمن.
- ◀ **وحدة البيانات:** سجل حساب وحالته وعضوياته وامتيازاته.
- ◀ **مثال:** يحدد لحساب متدرب في معمل تدريبي تاريخ تعطيل بعد انتهاء المهمة.



الحساب (Account) (الشكل)

SLIDE 8 • ACCOUNT

الحساب



الأجهزة والأدوات

- مدير الحسابات
- معرفات SID
- مجموعات محلية أو مركزية
- سجل أحداث الأمن

البروتوكولات والمعايير

- في AC-2 Account Management
NIST SP 800-53 Rev. 5

يحدد لحساب متدرب في معمل تدريبي تاريخ تعطيل بعد انتهاء المهمة

الوظائف الرئيسية

- ربط الهوية بسياسات وصول محددة
- الإنشاء
- توفير هوية نظامية
- المراجعة
- التحقق من الحاجة المستمرة

الحساب هو تمثيل نظامي لهوية يتيح للنظام إدارة المصادقة والتصاريح وسلوك الاستخدام



- المجموعة هي تجميع لهويات أو حسابات تشترك في صلاحيات محددة.
- وظيفتها تبسيط منح الصلاحيات وإدارتها مقارنة بمنحها لكل مستخدم على حدة، لأن الصلاحية ترتبط بالحاجة الوظيفية بدلاً من هوية فردية متغيرة.
- الوظيفة:** إدارة الصلاحيات بصورة جماعية.
- المسؤوليات:** تجميع المستخدمين بحسب الحاجة الوظيفية، تنظيم الوصول، منح الصلاحيات للمجموعة، توحيد القرار، مراجعة العضوية، كشف الأعضاء غير اللازمين، إزالة العضوية غير اللازمة، خفض الامتيازات المتراكمة.
- البروتوكولات والمعايير:** AC-2، AC-3، AC-6 في NIST SP 800-53 Rev. 5.
- الأجهزة:** مجموعات Windows الأمنية، قوائم ACL، تعيينات المستخدم-الدور.
- وحدة البيانات:** عضوية مجموعة وصلاحيات موروثة أو معينة.
- مثال:** تمنح مجموعة موظفي التسجيل القراءة والكتابة لمجلد معاملات التسجيل فقط.



SLIDE 9 · GROUP

المجموعة



الأجهزة والأدوات

- مجموعات Windows الأمنية
- قوائم ACL
- تعيينات المستخدم - الدور

البروتوكولات والمعايير

- AC-2
- AC-3
- NIST SP 800-53 Rev. 5 في AC-6

تمنح مجموعة موظفي التسجيل القراءة والكتابة لمجلد معاملات التسجيل فقط.

الوظائف الرئيسية

- إدارة الصلاحيات بصورة جماعية
- تجميع المستخدمين بحسب الحاجة الوظيفية
- تنظيم الوصول
- منح الصلاحيات للمجموعة
- توحيد القرار

المجموعة هي تجميع لهويات أو حسابات تشترك في صلاحيات محددة.



المصادقة (Authentication)

- المصادقة هي التحقق من ادعاء الهوية قبل الانتقال إلى قرار الصلاحية أو الوصول.
- وظيفتها إثبات هوية المستخدم أو الخدمة للنظام.
- نجاح المصادقة لا يساوي منح الإذن للوصول إلى ملف أو تنفيذ وظيفة بعينها.
- الوظيفة:** إثبات هوية طالب الوصول.
- المسؤوليات:** التحقق من الهوية، مطابقة عامل المصادقة، مقاومة محاولات الدخول غير الناجحة، تقييد المحاولات المخالفة، دعم عوامل مصادقة مناسبة، رفع موثوقية الإثبات، تسجيل أحداث الدخول عند الحاجة، تمكين المراجعة اللاحقة.
- البروتوكولات والمعايير:** عائلة 5، NIST SP 800-53 Rev. 5، AC-7 Unsuccessful Logon Attempts، Identification and Authentication.
- الأجهزة:** كلمة مرور، رمز، عامل حيابة، عامل حيوي، آلية تسجيل دخول نظام التشغيل.
- وحدة البيانات:** نتيجة إثبات الهوية، نجاح أو فاشل.
- مثال:** يثبت حساب مدخل بيانات الخدمة هويته بكلمة مرور وعامل إضافي قبل إنشاء جلسة عمل.



(الشكل) (Authentication) المصادقة

SLIDE 10 · AUTHENTICATION

المصادقة

المصادقة هي التحقق من ادعاء الهوية قبل الانتقال إلى قرار الصلاحية أو الوصول. وظيفتها إثبات هوية المستخدم أو الخدمة للنظام. نجاح المصادقة لا يساوي منح الإذن للوصول إلى ملف أو تنفيذ وظيفة بعينها.



الأجهزة والأدوات

- كلمة مرور
- رمز
- عامل حيازة
- عامل حيوي
- آلية تسجيل دخول نظام التشغيل

البروتوكولات والمعايير

- Identification and Authentication
- AC-7 Unsuccessful Logon Attempts
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- إثبات هوية طالب الوصول
- التحقق من الهوية
- مطابقة عامل المصادقة
- مقاومة محاولات الدخول غير الناجحة
- تقييد المحاولات المخالفة

يثبت حساب مدخل بيانات الخدمة هويته بكلمة مرور وعامل إضافي قبل إنشاء جلسة عمل.

المصادقة هي التحقق من ادعاء الهوية قبل الانتقال إلى قرار الصلاحية أو الوصول. وظيفتها إثبات هوية المستخدم أو الخدمة للنظام.



(Authorization) التفويض

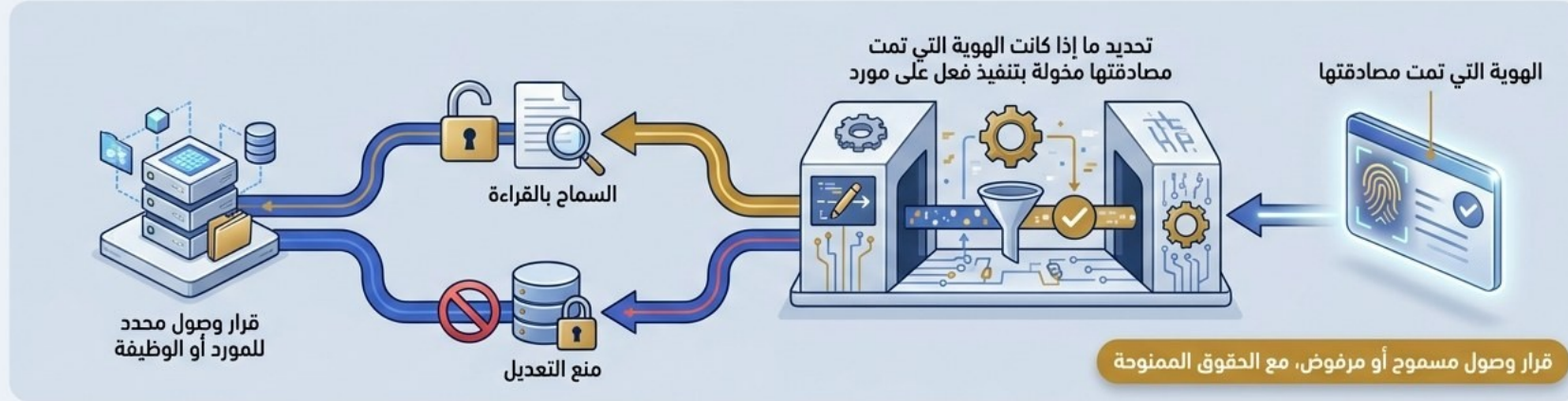
- ◀ التفويض هو تحديد ما إذا كانت الهوية التي تمت مصادقتها مخولة بتنفيذ فعل على مورد.
- ◀ وظيفته تحويل الهوية الموثقة إلى قرار وصول محدد للمورد أو الوظيفة، مثل السماح بالقراءة أو منع التعديل.
- ◀ **الوظيفة:** إصدار قرار وصول بعد المصادقة.
- ◀ **المسؤوليات:** فحص التصاريح، مقارنة الحق المطلوب، تطبيق السياسات، فرض قواعد المنشأة، السماح أو المنع، إنتاج قرار قابل للإنفاذ، مراعاة الأدوار أو المجموعات، ربط الوصول بالمسؤولية، مراجعة التفويضات، تحديثها عند تغير المهام.
- ▶ **البروتوكولات والمعايير:** AC-3 Access Enforcement في NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** ACL، DACL، مجموعات الأمن، الأدوار، واصف الأمان.
- ◀ **وحدة البيانات:** قرار وصول مسموح أو مرفوض، مع الحقوق الممنوحة.
- ◀ **مثال:** يسمح التفويض لموظف التسجيل بتعديل معاملة ويمنع الطالب من تعديلها.



(الشكل) (Authorization) التفويض

SLIDE 11 · AUTHORIZATION

التفويض



الأجهزة والأدوات

- ACL
- DACL
- مجموعات الأمن
- الأدوار
- واصف الأمان

البروتوكولات والمعايير

- في AC-3 Access Enforcement
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- إصدار قرار وصول بعد المصادقة
- فحص التصاريح
- مقارنة الحق المطلوب
- تطبيق السياسات
- فرض قواعد المنشأة

يسمح التفويض لموظف التسجيل بتعديل معاملة ويمنع الطالب من تعديلها

التفويض هو تحديد ما إذا كانت الهوية التي تمت مصادقتها مخولة بتنفيذ فعل على مورد



التحكم في الوصول (Access Control)

- ◀ التحكم في الوصول هو آليات تحدد من يصل إلى موارد نظام التشغيل وكيف يصل إليها.
- ◀ وظيفته منع الوصول غير المصرح به ووضع حدود واضحة للمستخدمين المصرح لهم، مع إمكانية مراجعة القرار والأحداث الناتجة عنه.
- ◀ **الوظيفة:** فرض حدود الوصول إلى الموارد.
- ◀ **المسؤوليات:** تعريف الأصول، حصر الموارد الحساسة، تحديد الموضوعات، تعيين طالبي الوصول، فرض التصاريح، تنفيذ الحقوق المقررة، تدقيق محاولات الوصول، توثيق الأحداث المهمة، إلغاء الصلاحيات عند الحاجة، إزالة الحقوق المتقدمة.
- ▶ **البروتوكولات والمعايير:** AC-3 Access Enforcement, AC-5 Separation of Duties, AC-6 Least Privilege.
- ◀ **الأجهزة:** ACL, DACL, SACL, المجموعات، الأدوار، تسميات SELinux.
- ◀ **وحدة البيانات:** قرار السماح أو المنع، وسجل تدقيق اختياري.
- ◀ **مثال:** يقرأ محلل السجلات مجلد السجلات، لكنه لا يملك تعديل محتواه.



التحكم في الوصول (Access Control) (الشكل)

SLIDE 12 · ACCESS CONTROL

التحكم في الوصول



الأجهزة والأدوات

- ACL
- DACL
- SACL
- المجموعات
- الأدوار

البروتوكولات والمعايير

- AC-3 Access Enforcement
- AC-5 Separation of Duties
- AC-6 Least Privilege

الوظائف الرئيسية

- فرض حدود الوصول إلى الموارد
- تعريف الأصول
- حصر الموارد الحساسة
- تحديد الموضوعات
- تعيين طالبي الوصول

يقرأ محلل السجلات مجلد السجلات، لكنه لا يملك تعديل محتواه

التحكم في الوصول هو آليات تحدد من يصل إلى موارد نظام التشغيل وكيف يصل إليها.



سياسة الأمان (Security Policy)

- ◀ سياسة الأمان هي قواعد معلنة تحدد كيف يدار الوصول والحسابات والتدقيق والحماية في النظام.
- ◀ وظيفتها توجيه تنفيذ الضوابط بصورة متسقة وقابلة للمراجعة، فلا تبقى القواعد مكتوبة بمعزل عن إعدادات النظام الفعلية.
- ◀ **الوظيفة:** توجيه تطبيق الضوابط الأمنية.
- ◀ **المسؤوليات:** تحديد القواعد، إعلان متطلبات الوصول، توزيع المسؤوليات، إسناد الأدوار بوضوح، ربط الصلاحيات بالحاجة، منع الحقوق العامة، مراجعة الضوابط، كشف الانحرافات، تحديثها عند تغير المخاطر، الاستجابة للحاجة التشغيلية.
- ▶ **البروتوكولات والمعايير:** SELinux سياسات، AC-1 Policy and Procedures, NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** إعدادات نظام التشغيل، سياسات مجموعات، ACL، سياسات SELinux، سجلات التدقيق.
- ◀ **وحدة البيانات:** وثيقة سياسة أو إعدادات فنية قابلة للإنفاذ.
- ◀ **مثال:** تمنع سياسة الشركة استخدام الحساب الإداري في العمل اليومي وتلزم مراجعة الامتيازات.



سياسة الأمان (Security Policy) (الشكل)

SLIDE 13 • SECURITY POLICY

سياسة الأمان



وثيقة سياسة أو إعدادات فنية قابلة للإنفاذ.

الأجهزة والأدوات

- إعدادات نظام التشغيل
- سياسات مجموعات ACL
- سياسات SELinux
- سجلات التدقيق

البروتوكولات والمعايير

- AC-1 Policy and Procedures
- NIST SP 800-53 Rev. 5
- سياسات SELinux

الوظائف الرئيسية

- توجيه تطبيق الضوابط الأمنية
- تحديد القواعد
- إعلان متطلبات الوصول
- توزيع المسؤوليات
- إسناد الأدوار بوضوح

تمنع سياسة الشركة استخدام الحساب الإداري في العمل اليومي وتلزم مراجعة الامتيازات.

سياسة الأمان هي قواعد معلنة تحدد كيف يدار الوصول والحسابات والتدقيق والحماية في النظام.

قراءة سياسة التحكم في الوصول



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

النموذج: ملخص سياسة التحكم في الوصول إلى موارد نظام التشغيل

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

ملخص سياسة التحكم في الوصول إلى موارد نظام التشغيل

تاريخ نفاذ السياسة: 2026-02-01

نطاق التطبيق: خوادم الأنظمة الرقمية التعليمية، مجلدات الخدمة المشتركة، سجلات التدقيق، ونسخ الإعدادات المحمية.

الأصول ذات الحساسية العالية: ملفات إعدادات النظام، سجلات المصادقة، سجلات التدقيق، قاعدة بيانات المستخدمين، وملفات النسخ الاحتياطي.

قاعدة منح الصلاحيات: تمنح الصلاحيات للدور الوظيفي فقط وبالحد الأدنى اللازم لتنفيذ مهمة محددة، ولا تمنح صلاحيات إدارية كاملة لحسابات العمل اليومية.

المصادقة المطلوبة: مصادقة متعددة العوامل عند الدخول عن بُعد أو عند تنفيذ إجراء إداري على مورد حساس.

قاعدة فصل المهام: لا يجمع الحساب نفسه بين إنشاء طلب تعديل صلاحيات واعتماد الطلب النهائي أو مراجعة سجل التدقيق الخاص به.

مراجعة الصلاحيات: تراجع تعيينات الأدوار وقوائم التحكم في الوصول كل ثلاثة أشهر وعند انتقال الموظف أو انتهاء مهمته.

التدقيق والاستجابة: تسجل محاولات الدخول وتغيير الأذونات وطلبات الوصول المرفوضة في سجل النظام، وتراجع الأحداث غير المعتادة من دور مدقق الأمن.

السياسة تدعم ضوابط التحكم في الوصول والمصادقة والتدقيق، وتطبق على المستخدمين والخدمات والحسابات الإدارية.

الاعتماد

المسؤول

مقدم الطلب

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- تبدأ قراءة السياسة بتاريخ نفاذها، وهو 2026-02-01، ثم نطاقها الذي يشمل الخوادم ومجلدات الخدمة وسجلات التدقيق ونسخ الإعدادات المحمية.
- ركز على قاعدة منح الصلاحيات للدور الوظيفي وبالحد الأدنى اللازم.
- تربط السياسة بين المصادقة متعددة العوامل، وفصل المهام، ومراجعة تعيينات الأدوار وقوائم التحكم في الوصول كل ثلاثة أشهر.



- ◀ الموضوع هو كيان نشط يطلب تنفيذ فعل على كائن، مثل عملية أو مستخدم أو خدمة.
- ◀ وظيفته تمثيل الجهة التي يقيم النظام طلب وصولها إلى المورد، بحيث يسأل النظام إن كان للموضوع حق تنفيذ الفعل المطلوب على الكائن.
- ◀ **الوظيفة:** تمثيل طالب الفعل على المورد.
- ◀ **المسؤوليات:** طلب عملية محددة، تحديد الفعل المطلوب، تقديم هوية أو سياق أمني، ربط الطلب بالهوية، الخضوع لقواعد الوصول، قبول قرار السياسة، تسجيل محاولات الوصول عند تفعيل التدقيق، دعم التحقيق اللاحق.
- ◀ **البروتوكولات والمعايير:** نموذج موضوع-فعل-كائن في SELinux، ضوابط AC في NIST SP 800-53 Rev. 5، سياق SELinux.
- ◀ **الأجهزة:** عملية نظام، حساب مستخدم، خدمة، سياق SELinux.
- ◀ **وحدة البيانات:** طلب وصول من موضوع إلى كائن.
- ◀ **مثال:** تطلب عملية خادم ويب قراءة ملف إعدادات لخدمة تعليمية.

الموضوع هو كيان نشط يطلب تنفيذ فعل على كائن، مثل عملية أو مستخدم أو خدمة.



- الكائن هو مورد قابل للحماية يطلب الموضوع الوصول إليه أو إجراء عملية عليه.
- وظائفه تمثيل هدف قرار التحكم في الوصول، وقد يكون ملفاً أو دليلاً أو طابعة أو مفتاح سجل أو مورداً من موارد النظام.
- الوظيفة:** تحديد هدف قرار الوصول.
- المسؤوليات:** حمل الملكية، إسناد مسؤولية المورد، حمل التسميات أو ACL، تعريف قواعد الوصول، قبول أو رفض العملية وفق السياسة، إنفاذ القرار، إنتاج سجل تدقيق عند طلب السياسة، دعم المراجعة والمساءلة.
- البروتوكولات والمعايير:** AC-3، AU-2، AU-9 في NIST SP 800-53 Rev. 5.
- الأجهزة:** ملف، دليل، طابعة، مفتاح سجل، مقبس، عملية أو مورد SELinux.
- وحدة البيانات:** مورد مؤمن ووصف أمني أو قائمة وصول.
- مثال:** سجل التدقيق الأمني كائن يجب أن يقرأه مدقق الأمن دون صلاحية تعديل أو حذف.



الكائن (Object) (الشكل)

SLIDE 16 · OBJECT

الكائن



الأجهزة والأدوات

- ملف
- دليل
- طباعة
- مفتاح سجل
- مقبس

البروتوكولات والمعايير

- AC-3
- AU-2
- Rev. 5 في NIST SP 800-53 في AU-9

الوظائف الرئيسية

- تحديد هدف قرار الوصول
- حمل الملكية
- إسناد مسؤولية المورد
- حمل التسميات أو ACL
- تعريف قواعد الوصول

سجل التدقيق الأمني كائن يجب أن يقرأه مدقق الأمن دون صلاحية تعديل أو حذف

الكائن هو مورد قابل للحماية يطلب الموضوع الوصول إليه أو إجراء عملية عليه



تصريح الوصول (Access Permission)

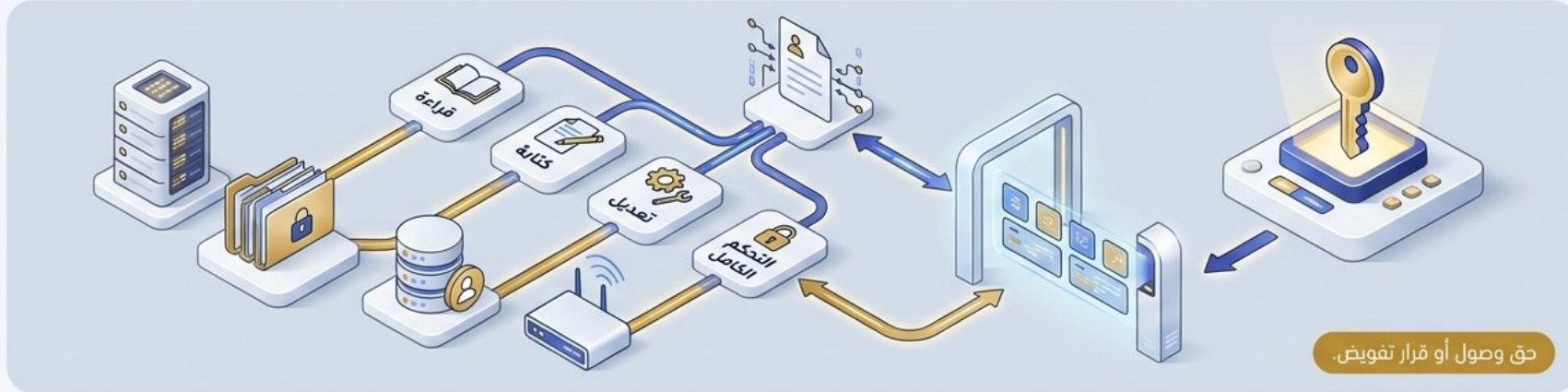
- ◀ تصريح الوصول هو حق محدد يبين نوع الإجراء المسموح أو الممنوع على كائن.
- ◀ وظيفته ترجمة سياسة الوصول إلى أفعال قابلة للإنفاذ، مثل القراءة أو الكتابة أو التعديل أو التحكم الكامل، مع ربط كل حق بالحاجة الفعلية.
- ◀ **الوظيفة:** تحويل السياسة إلى حق قابل للإنفاذ.
- ◀ **المسؤوليات:** تحديد نوع الفعل، تعريف الحق المطلوب، ربطه بموضوع أو مجموعة أو دور، تحديد الجهة المخولة، دعم المنع أو السماح، تطبيق القرار، دعم المراجعة، فحص مناسبة الحقوق، تقليل الإفراط في الصلاحيات، منع التحكم الكامل غير اللازم.
- ▶ **البروتوكولات والمعايير:** AC-3 Access Enforcement, AC-6 Least Privilege, NIST SP 800-53 Rev. 5.
- ▶ **الأجهزة:** Read, Write, Modify, Full control, ACE, ACL.
- ◀ **وحدة البيانات:** حق وصول أو قرار تفويض.
- ◀ **مثال:** يمنح مدقق الأمن تصريح قراءة فقط لسجل التدقيق الأمني.



تصريح الوصول (Access Permission) (الشكل)

SLIDE 17 · ACCESS PERMISSION

تصريح الوصول



الأجهزة والأدوات

- Read
- Write
- Modify
- Full control
- ACE

البروتوكولات والمعايير

- AC-3 Access Enforcement
- AC-6 Least Privilege
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- تحويل السياسة إلى حق قابل للإنفاذ
- تحديد نوع الفعل
- تعريف الحق المطلوب
- ربطه بموضوع أو مجموعة أو دور
- تحديد الجهة المخولة

يمنح مدقق الأمن تصريح قراءة فقط لسجل التدقيق الأمني.

تصريح الوصول هو حق محدد يبين نوع الإجراء المسموح أو الممنوع على كائن.



- ◀ قائمة التحكم في الوصول هي قائمة من مدخلات التحكم في الوصول تحدد الحقوق المسموح بها أو الممنوعة أو المدققة للجهات المحددة.
- ◀ وظيفتها تطبيق التصاريح على الكائنات القابلة للتأمين، بحيث يحدد كل مدخل ACE جهة وحقوقاً محددة.
- ◀ **الوظيفة:** تطبيق التصاريح على كائن محدد.
- ◀ **المسؤوليات:** تحديد الوصي أو الجهة، تعيين صاحب الحق، ربط الحقوق، تحديد القراءة أو الكتابة، تحديد السماح أو المنع، فرض القرار، دعم التدقيق، تسجيل محاولات الوصول، مراجعة الترتيب والمحتوى، كشف المدخلات غير المناسبة.
- ◀ **البروتوكولات والمعايير:** AU-2، AC-3، SACL، DACL في NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** SACL، DACL، ACE، ACL، واصف الأمان.
- ◀ **وحدة البيانات:** قائمة ACE مرتبطة بكائن قابل للتأمين.
- ◀ **مثال:** تمنح ACL لمجلد سجلات القراءة لمدقق الأمن وتمنع التعديل لغيره.

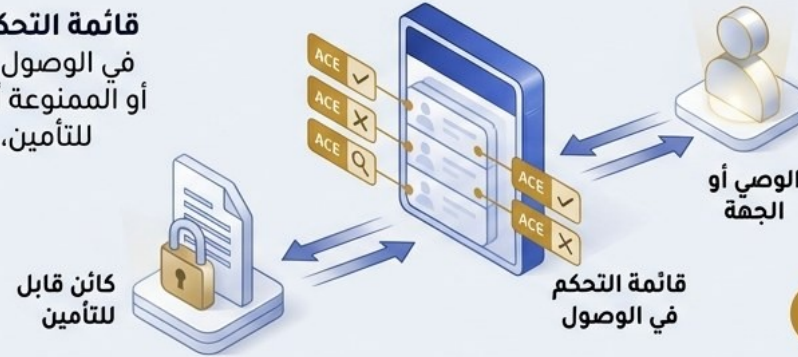


قائمة التحكم في الوصول (Access Control List - ACL) (الشكل)

SLIDE 18 • ACCESS CONTROL LIST - ACL

قائمة التحكم في الوصول

قائمة التحكم في الوصول ACE من التحكم في الوصول تحدد الحقوق المسموح بها أو الممنوعة أو المدققة على الكائنات القابلة للتأمين، بحيث يحدد كل محيداً للتأمين.



قائمة التحكم في الوصول هي قائمة من مدخلات التحكم في الوصول تحدد الحقوق المسموح بها أوقفة للجهات المحددة. وظيفتها تطبيق التصاريح على الكائنات بحيث يحدد كل مدخل ACE جهة وحقوقاً محددة.

قائمة ACE مرتبطة بكائن قابل للتأمين.

الأجهزة والأدوات

- ACL
- ACE
- DACL
- SACL
- واصف الأمان

البروتوكولات والمعايير

- DACL
- SACL
- AC-3
- NIST SP 800-53 Rev. 5 في AU-2

الوظائف الرئيسية

- تطبيق التصاريح على كائن محدد
- تحديد الوصي أو الجهة
- تعيين صاحب الحق
- ربط الحقوق
- تحديد القراءة أو الكتابة

تمنح ACL لمجلد سجلات القراءة لمدقق الأمن وتمنع التعديل لغيره.

قائمة التحكم في الوصول هي قائمة من مدخلات التحكم في الوصول تحدد الحقوق المسموح بها أو الممنوعة أو المدققة للجهات المحددة.



مصفوفة الوصول (Access Matrix)



- ◀ مصفوفة الوصول هي تمثيل منظم لعلاقة الموضوعات أو المجالات بالكائنات والحقوق المسموحة عليها.
- ◀ وظيفتها تحليل من يملك أي حق على أي مورد، ثم تحويل التصميم إلى ACL أو قدرات أو أدوار مناسبة للنظام.
- ◀ **الوظيفة:** تحليل علاقة الموضوعات بالكائنات والحقوق.
- ◀ **المسؤوليات:** حصر الموضوعات، تحديد طالبي الوصول، حصر الكائنات، تحديد الموارد المحمية، تحديد الحقوق، توثيق الأفعال المسموحة، كشف الصلاحيات الزائدة، تحديد المخالفات، توثيق قرار الوصول، دعم التحويل إلى إعدادات نظامية.
- ◀ **البروتوكولات والمعايير:** Access Matrix في الفصل 17.5 من المرجع، RBAC، ACL، AC-3.
- ◀ **الأجهزة:** جدول وصول، ACL، أدوار RBAC، قوائم مجموعات.
- ◀ **وحدة البيانات:** جدول موضوع × كائن × حقوق.
- ◀ **مثال:** تربط المصفوفة دور مدخل البيانات ودور المشغل ودور المدقق بسجلات الخدمة وطلبات تغيير الصلاحيات.



مصفوفة الوصول (Access Matrix) (الشكل)

SLIDE 19 · ACCESS MATRIX

مصفوفة الوصول



الأجهزة والأدوات

- جدول وصول
- ACL
- أدوار RBAC
- قوائم مجموعات

البروتوكولات والمعايير

- Access Matrix في الفصل 17.5 من المرجع
- AC-3
- ACL
- RBAC

الوظائف الرئيسية

- تحليل علاقة الموضوعات بالكائنات والحقوق
- حصر الموضوعات
- تحديد طالبي الوصول
- حصر الكائنات
- تحديد الموارد المحمية

تربط المصفوفة دور مدخل البيانات ودور المشغل ودور المدقق بسجلات الخدمة وطلبات تغيير الصلاحيات.

مصفوفة الوصول هي تمثيل منظم لعلاقة الموضوعات أو المجالات بالكائنات والحقوق المسموحة عليها.

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مصفوفة التحكم في الوصول للموارد التشغيلية

نموذج تعيين الصلاحيات حسب الدور الوظيفي، مراجعة 15-04-2026

المورد أو الكائن	مالك الكائن	دور مدخل بيانات الخدمة	دور مشغل النظام	دور مدقق الأمن	دور مدير الخدمة	صابط فصل المهام
سجل طلبات الدعم التعليمية	مدير الخدمة	قراءة وكتابة	قراءة	قراءة فقط	قراءة واعتماد	لا يعتمد مدخل البيانات الطلب الذي أنشأه.
مجلد إعدادات الخادم	نظام التشغيل	لا وصول	قراءة وتنفيذ للإجراءات المعتمدة	لا وصول	لا وصول	لا تمنح الكتابة إلا لخدمة النظام ضمن إجراء تغيير معتمد.
سجل المصادقة اليومي	نظام التشغيل	لا وصول	قراءة فقط	قراءة فقط	لا وصول	يمنع تعديل السجل أو حذفه من جميع الأدوار البشرية.
سجل التدقيق الأمني	نظام التشغيل	لا وصول	لا وصول	قراءة فقط	لا وصول	يظل السجل مملوكاً لنظام التشغيل ومحمياً من التعديل بأثر رجعي.
طلب تعديل صلاحيات المستخدمين	مدير الخدمة	إنشاء فقط	تنفيذ التغيير بعد اعتماد	قراءة فقط	اعتماد فقط	لا يجمع الدور نفسه بين الإنشاء والاعتماد والتنفيذ.
النسخة الاحتياطية المشفرة	نظام التشغيل	لا وصول	تنفيذ الاستعادة المعتمدة فقط	قراءة بيانات الفهرس فقط	اعتماد طلب الاستعادة	لا يطلع مدير الخدمة على محتوى النسخة الاحتياطية دون حاجة عمل موقعة.

المصطلحات: لا وصول، قراءة، كتابة، تنفيذ، اعتماد. تستخدم المصفوفة كأساس لبناء قائمة التحكم في الوصول لكل مورد.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- أقرأ المورد أولاً، ثم مالكه، ثم الحق الممنوح لكل دور من الأدوار الوظيفية الأربعة.
- يمنح سجل طلبات الدعم التعليمية لمدخل البيانات قراءة وكتابة، بينما يمنع الوصول إلى سجل التدقيق الأمني من مدخل البيانات ومشغل النظام ومدير الخدمة.
- لاحظ أن طلب تعديل الصلاحيات يوزع بين الإنشاء والاعتماد والتنفيذ، فلا يجمع الدور نفسه هذه الأفعال الحساسة.

مثال محلول على النموذج، تصميم مصفوفة وصول

المستند: مصفوفة التحكم في الوصول للموارد التشغيلية

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مصفوفة التحكم في الوصول للموارد التشغيلية

نموذج تعيين الصلاحيات حسب الدور الوظيفي، مراجعة 15-04-2026

المورد أو الكائن	مالك الكائن	دور مدخل بيانات الخدمة	دور مشغل النظام	دور مدقق الأمن	دور مدير الخدمة	صايغ فصل المهام

المصطلحات: لا وصول، قراءة، كتابة، تنفيذ، اعتماد. تستخدم المصفوفة كأساس لبناء قائمة التحكم في الوصول لكل مورد.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- المعطيات: تتضمن الحالة ستة موارد حساسة، وأربعة أدوار وظيفية، وضوابط واضحة لفصل المهام.
- المطلوب تعبئة مصفوفة وصول تحدد المالك وحقوق كل دور، مع منع جمع إنشاء طلب تعديل الصلاحيات واعتماده وتنفيذه في دور واحد.
- تستخدم البيانات الواردة في المستند، ومنها سجل المصادقة اليومي وسجل التدقيق الأمني والنسخة الاحتياطية المشفرة.

الخطوة 1 من 3: إدخال موارد الخدمة وإعدادات الخادم

- يسجل الصف الأول مورد سجل طلبات الدعم التعليمية، ويحدد مدير الخدمة مالكاً له.
- يمنح دور مدخل بيانات الخدمة قراءة وكتابة لأن مهمته تتطلب معالجة الطلبات، بينما يقرأ مدير الخدمة ويعتمد.
- في الصف الثاني يسجل مجلد إعدادات الخادم، ويملكه نظام التشغيل.
- يمنح مشغل النظام قراءة وتنفيذ الإجراءات المعتمدة فقط، ولا يمنح مدخل البيانات أي وصول.

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية

جازان، المملكة العربية السعودية

الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

المستند: مصفوفة التحكم في الوصول للموارد التشغيلية

مصفوفة التحكم في الوصول للموارد التشغيلية

نموذج تعيين الصلاحيات حسب الدور الوظيفي، مراجعة 15-04-2026

المورد أو الكائن	مالك الكائن	دور مدخل بيانات الخدمة	دور مشغل النظام	دور مدقق الأمن	دور مدير الخدمة	صايغ فصل المهام
سجل طلبات الدعم التعليمية	مدير الخدمة	قراءة وكتابة	قراءة	قراءة فقط	قراءة واعتماد	لا يعتمد مدخل البيانات الطلب الذي أنشأه.
مجلد إعدادات الخادم	نظام التشغيل	لا وصول	قراءة وتنفيذ للإجراءات المعتمدة	لا وصول	لا وصول	لا تمنح الكتابة إلا لخدمة النظام ضمن إجراء تغيير معتمد.

المصطلحات: لا وصول، قراءة، كتابة، تنفيذ، اعتماد. تستخدم المصفوفة كأساس لبناء قائمة التحكم في الوصول لكل مورد.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

الخطوة 2 من 3: حماية سجلات المصادقة والتدقيق



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

المستند: مصفوفة التحكم في الوصول للموارد التشغيلية

مصفوفة التحكم في الوصول للموارد التشغيلية

نموذج تعيين الصلاحيات حسب الدور الوظيفي، مراجعة 15-04-2026

المورد أو الكائن	مالك الكائن	دور مدخل بيانات الخدمة	دور مشغل النظام	دور مدقق الأمن	دور مدير الخدمة	صابط فصل المهام
سجل طلبات الدعم التعليمية	مدير الخدمة	قراءة وكتابة	قراءة	قراءة فقط	قراءة واعتماد	لا يعتمد مدخل البيانات الذي أنشأه.
مجلد إعدادات الخادم	نظام التشغيل	لا وصول	قراءة وتنفيذ للإجراءات المعتمدة	لا وصول	لا وصول	لا تمنح الكتابة إلا لخدمة النظام ضمن إجراء تغيير معتمد.
سجل المصادقة اليومي	نظام التشغيل	لا وصول	قراءة فقط	قراءة فقط	لا وصول	يمنع تعديل السجل أو حذفه من جميع الأدوار البشرية.
سجل التدقيق الأمني	نظام التشغيل	لا وصول	لا وصول	قراءة فقط	لا وصول	يظل السجل مملوكاً لنظام التشغيل ومحميّاً من التعديل بأثر رجعي.

المصطلحات: لا وصول، قراءة، كتابة، تنفيذ، اعتماد. تستخدم المصفوفة كأساس لبناء قائمة التحكم في الوصول لكل مورد.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

يسجل الصف الثالث سجل المصادقة اليومي ويجعل نظام التشغيل ماله.

لا يمنح مدخل البيانات وصولاً، ويعطي مشغل النظام ومدقق الأمن قراءة فقط.

في الصف الرابع يسجل سجل التدقيق الأمني، ويبقى مملوكاً لنظام التشغيل.

يمنح مدقق الأمن القراءة فقط، ولا يمنح أي دور بشري حق الكتابة أو الحذف، لأن ذلك يحمي سلامة السجل.



الخطوة 3 من 3: توزيع إنشاء الطلب واعتماده وتنفيذه

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: مصفوفة التحكم في الوصول للموارد التشغيلية

مصفوفة التحكم في الوصول للموارد التشغيلية

نموذج تعيين الصلاحيات حسب الدور الوظيفي، مراجعة 15-04-2026

المورد أو الكائن	مالك الكائن	دور مدخل بيانات الخدمة	دور مشغل النظام	دور مدقق الأمن	دور مدير الخدمة	صابط فصل المهام
سجل طلبات الدعم التعليمية	مدير الخدمة	قراءة وكتابة	قراءة	قراءة فقط	قراءة واعتماد	لا يعتمد مدخل البيانات الطلب الذي أنشأه.
مجلد إعدادات الخادم	نظام التشغيل	لا وصول	قراءة وتنفيذ للإجراءات المعتمدة	لا وصول	لا وصول	لا تمنح الكتابة إلا لخدمة النظام ضمن إجراء تغيير معتمد.
سجل المصادقة اليومي	نظام التشغيل	لا وصول	قراءة فقط	قراءة فقط	لا وصول	يمنع تعديل السجل أو حذفه من جميع الأدوار البشرية.
سجل التدقيق الأمني	نظام التشغيل	لا وصول	لا وصول	قراءة فقط	لا وصول	يظل السجل مملوكاً لنظام التشغيل ومحميّاً من التعديل بأثر رجعي.
طلب تعديل صلاحيات المستخدمين	مدير الخدمة	إنشاء فقط	تنفيذ التغيير بعد اعتماد	قراءة فقط	اعتماد فقط	لا يجمع الدور نفسه بين الإنشاء والاعتماد والتنفيذ.
النسخة الاحتياطية المشفرة	نظام التشغيل	لا وصول	تنفيذ الاستعادة المعتمدة فقط	قراءة بيانات الفهرس فقط	اعتماد طلب الاستعادة	لا يطلع مدير الخدمة على محتوى النسخة الاحتياطية دون حاجة عمل موثقة.

المصطلحات: لا وصول، قراءة، كتابة، تنفيذ، اعتماد. تستخدم المصفوفة كأساس لبناء قائمة التحكم في الوصول لكل مورد.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يسجل الصف الخامس طلب تعديل صلاحيات المستخدمين، ويمنح مدخل البيانات إنشاء الطلب فقط، ومدير الخدمة اعتماده فقط، ومشغل النظام تنفيذ التغيير بعد الاعتماد.
- في الصف السادس لا يملك مدخل البيانات وصولاً، وينفذ مشغل النظام الاستعادة المعتمدة فقط، ويقرأ مدقق الأمن بيانات الفهرس فقط، ويعتمد مدير الخدمة طلب الاستعادة.
- الناتج مصفوفة تطبق أقل الامتيازات وفصل المهام على جميع الموارد الستة.



الملكية (Ownership)

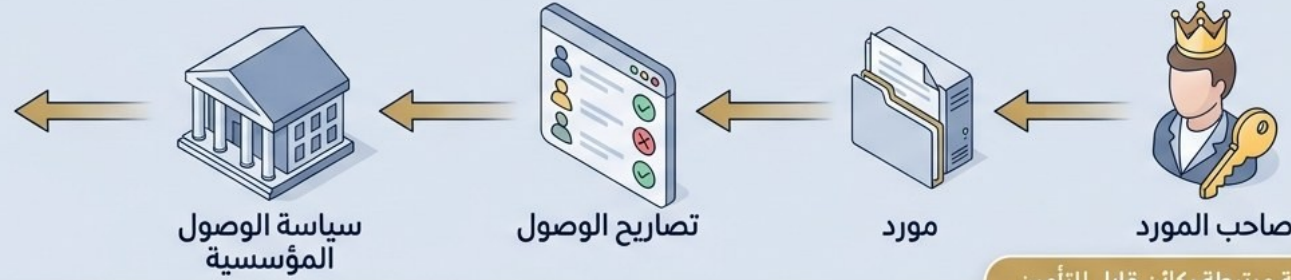
- ◀ الملكية هي علاقة تحدد صاحب المورد القادر على إدارة تصاريح الوصول إليه في نموذج Windows المعروف.
- ◀ وظيفتها إسناد مسؤولية أولية عن منح التصاريح للمبادئ الأمنية أو المجموعات، مع بقاء القرار مقيداً بسياسة الوصول المؤسسية.
- ◀ **الوظيفة:** إسناد مسؤولية إدارة تصاريح المورد.
- ◀ **المسؤوليات:** تعيين مالك، تحديد صاحب المورد، منح أو تعديل التصاريح وفق السياسة، تطبيق قواعد المنشأة، حماية المورد، الحفاظ على سرية محتواه، مراجعة المشاركة، فحص الجهات المخولة، منع منح صلاحيات غير لازمة، دعم أقل الامتيازات.
- ◀ **البروتوكولات والمعايير:** AC-3, AC-6, NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** مالك الكائن، ACL، مجموعات الأمن، واصف الأمان.
- ◀ **وحدة البيانات:** خاصية ملكية مرتبطة بكائن قابل للتأمين.
- ◀ **مثال:** يظل سجل التدقيق الأمني مملوكاً لنظام التشغيل ومحمياً من التعديل بأثر رجعي.



الملكية (Ownership) (الشكل)

SLIDE 25 · OWNERSHIP

الملكية



خاصية ملكية مرتبطة بكائن قابل للتأمين.

الأجهزة والأدوات

- مالك الكائن
- ACL
- مجموعات الأمن
- واصف الأمان

البروتوكولات والمعايير

- AC-3
- AC-6
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- إسناد مسؤولية إدارة تصاريح المورد
- تعيين مالك
- تحديد صاحب المورد
- منح أو تعديل التصاريح وفق السياسة
- تطبيق قواعد المنشأة

يظل سجل التدقيق الأمني مملوكاً لنظام التشغيل ومحمياً من التعديل بأثر رجعي.

الملكية هي علاقة تحدد صاحب المورد القادر على إدارة تصاريح الوصول إليه في نموذج Windows المعروض.



مبدأ أقل الامتيازات (Least Privilege)



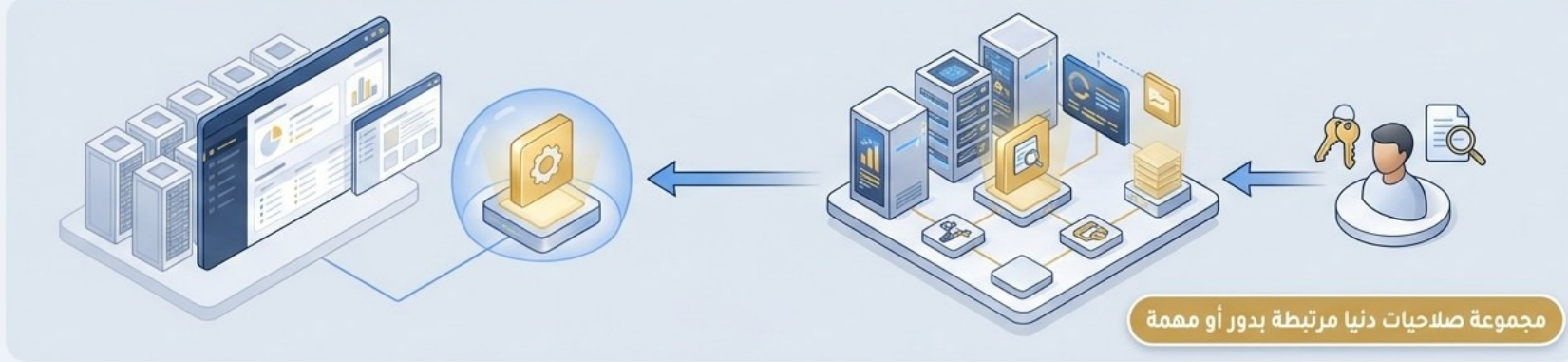
- ◀ مبدأ أقل الامتيازات هو منح المستخدم أو العملية أقل صلاحيات لازمة لأداء المهمة المصرح بها.
- ◀ وظيفته تقليل نطاق الضرر إذا أخطأ المستخدم أو تعرض الحساب أو التطبيق للاختراق، فلا تتحول مهمة محدودة إلى قدرة إدارية واسعة.
- ◀ **الوظيفة:** تقليل الضرر الناتج عن الحقوق الزائدة.
- ◀ **المسؤوليات:** تقييد الحسابات المميزة، حصر الوظائف الحساسة، مراجعة الامتيازات، كشف الصلاحيات المتراكمة، فصل الاستخدام اليومي عن الإدارة، منع خلط الحسابات، منع تنفيذ الوظائف المميزة لغير المخولين، حماية النظام من التوسع غير المبرر.
- ▶ **البروتوكولات والمعايير:** AC-6 Least Privilege, AC-3, NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** حساب مستخدم قياسي، حساب إداري منفصل، مجموعات، ACL، مراجعات امتيازات.
- ◀ **وحدة البيانات:** مجموعة صلاحيات دنيا مرتبطة بدور أو مهمة.
- ◀ **مثال:** يقرأ مدقق الأمن سجل التدقيق، ولا يملك حذفه أو تعديله.



مبدأ أقل الامتيازات (Least Privilege) (الشكل)

SLIDE 26 · LEAST PRIVILEGE

مبدأ أقل الامتيازات



الأجهزة والأدوات

- حساب مستخدم قياسي
- حساب إداري منفصل
- مجموعات ACL
- مراجعات امتيازات

البروتوكولات والمعايير

- AC-6 Least Privilege
- AC-3
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- تقليل الضرر الناتج عن الحقوق الزائدة
- تقييد الحسابات المميزة
- حصر الوظائف الحساسة
- مراجعة الامتيازات
- كشف الصلاحيات المتراكمة

يقرأ مدقق الأمن سجل التدقيق، ولا يملك حذفه أو تعديله

مبدأ أقل الامتيازات هو منح المستخدم أو العملية أقل صلاحيات لازمة لأداء المهمة المصرح بها.



فصل المهام (Separation of Duties)

- ◀ فصل المهام هو توزيع مهام أو صلاحيات حساسة بين أكثر من دور أو شخص لتقليل إساءة الاستخدام والخطأ.
- ◀ وظيفته منع جمع صلاحيات متعارضة بيد مستخدم أو عملية واحدة، مثل إنشاء تغيير حساس واعتماده وتنفيذه.
- ◀ **الوظيفة:** منع تضارب الصلاحيات الحساسة.
- ◀ **المسؤوليات:** تحديد المهام المتعارضة، كشف الأفعال غير المناسبة للجمع، تعريف أدوار منفصلة، توزيع المسؤوليات، ضبط الموافقات، اشتراط اعتماد مستقل، مراجعة التعيينات، كشف التعارضات، توثيق الاستثناءات، إبقاء الاستثناء قابلاً للمراجعة.
- ▶ **البروتوكولات والمعايير:** AC-5 Separation of Duties, RBAC، NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** أدوار RBAC، مجموعات، إجراءات موافقة، سجل تدقيق.
- ◀ **وحدة البيانات:** مصفوفة مهام متعارضة أو قاعدة منع تعارض الأدوار.
- ◀ **مثال:** ينشئ مدخل البيانات طلب تعديل الصلاحيات، ويعتمده مدير الخدمة، وينفذه مشغل النظام.



(الشكل) (Separation of Duties) فصل المهام

SLIDE 27 · SEPARATION OF DUTIES

فصل المهام



الأجهزة والأدوات

- أدوار RBAC
- مجموعات
- إجراءات موافقة
- سجل تدقيق

البروتوكولات والمعايير

- AC-5 Separation of Duties
- RBAC المقيد
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- منع تضارب الصلاحيات الحساسة
- تحديد المهام المتعارضة
- كشف الأفعال غير المناسبة للجمع
- تعريف أدوار منفصلة
- توزيع المسؤوليات

ينشئ مدخل البيانات طلب تعديل الصلاحيات، ويعتمده مدير الخدمة، وينفذه مشغل النظام.

فصل المهام هو توزيع مهام أو صلاحيات حساسة بين أكثر من دور أو شخص لتقليل إساءة الاستخدام والخطأ.



(Auditing) التدقيق

- ◀ التدقيق هو تسجيل ومراجعة أحداث أو محاولات وصول ذات صلة بالأمن والمساءلة.
- ◀ وظيفته دعم الاكتشاف والتحليل والمساءلة والتحقيق وتحسين إدارة الأمن، بشرط حماية السجلات ومراجعتها بدلاً من الاكتفاء بتجميعها.
- ◀ **الوظيفة:** دعم المساءلة والتحليل الأمني.
- ◀ **المسؤوليات:** اختيار الأحداث، تحديد ما يسجل، تحديد محتوى السجل، تضمين معلومات الحدث، حماية السجلات، منع التعديل غير المصرح، مراجعتها وتحليلها، اكتشاف الأنماط غير المعتادة، الاستجابة لفشل التسجيل، معالجة فقدان التوثيق.
- ◀ **البروتوكولات والمعايير:** AU-2، AU-3، AU-5، AU-6، AU-9، AU-11، AU-12 في NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** SACL، سجل أحداث الأمن، نظام تجميع سجلات، أدوات مراجعة وتحليل.
- ◀ **وحدة البيانات:** سجل تدقيق أو تقرير مراجعة أو تنبيه أمني.
- ◀ **مثال:** يسجل النظام محاولة وصول مرفوضة إلى سجل التدقيق الأمني.



التدقيق (Auditing) (الشكل)

SLIDE 28 • AUDITING

التدقيق



الأجهزة والأدوات

- SACL
- سجل أحداث الأمن
- نظام تجميع سجلات
- أدوات مراجعة وتحليل

البروتوكولات والمعايير

- AU-2
- AU-3
- AU-5
- AU-6
- AU-9

الوظائف الرئيسية

- دعم المساءلة والتحليل الأمني
- اختيار الأحداث
- تحديد ما يسجل
- تحديد محتوى السجل
- تضمين معلومات الحدث

يسجل النظام محاولة وصول مرفوضة إلى سجل التدقيق الأمني

التدقيق هو تسجيل ومراجعة أحداث أو محاولات وصول ذات صلة بالأمن والمساءلة



- ◀ سجل النظام هو سجل للأحداث التي تقع داخل أنظمة المؤسسة وشبكاتها، ويتكون من مدخلات مرتبطة بأحداث محددة.
- ◀ وظيفته دعم استكشاف الأعطال وتحسين الأداء وتسجيل أفعال المستخدمين والتحقيق في النشاط الضار.
- ◀ **الوظيفة:** توفير أدلة أحداث قابلة للمراجعة.
- ◀ **المسؤوليات:** التوليد، إنشاء مدخلات الأحداث، النقل، إيصال السجلات إلى وجهتها، التخزين، حفظ المعلومات اللازمة، التحليل، تفسير الأنماط والأخطاء، الحماية، منع العبث بالمحتوى، الاحتفاظ، إبقاء السجل للمدة المطلوبة، الإلتزام بالمنضبط، إزالة السجلات وفق الضبط.
- ◀ **البروتوكولات والمعايير:** NIST SP 800-92، AU-2، AU-3، AU-6، AU-9، AU-11 في NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** سجل أحداث Windows، سجلات نظام SACL، Linux، منصة إدارة سجلات.
- ◀ **وحدة البيانات:** مدخلة سجل تتضمن معلومات عن حدث محدد.
- ◀ **مثال:** يوثق السجل نجاح مصادقة أو محاولة وصول مرفوضة لملف حساس.



سجل النظام (System Log) (الشكل)

SLIDE 29 · SYSTEM LOG

سجل النظام



الأجهزة والأدوات

- سجل أحداث Windows
- سجلات نظام Linux
- SACL
- منصة إدارة سجلات

البروتوكولات والمعايير

- NIST SP 800-92
- AU-2
- AU-3
- AU-6
- AU-9

الوظائف الرئيسية

- توفير أدلة أحداث قابلة للمرجعة
- التوليد
- إنشاء مدخلات الأحداث
- النقل
- إيصال السجلات إلى وجهتها

يوثق السجل نجاح مصادقة أو محاولة وصول مرفوضة لملف حساس.

سجل النظام هو سجل للأحداث التي تقع داخل أنظمة المؤسسة وشبكاتهما، ويتكون من مدخلات مرتبطة بأحداث محددة.

قراءة مقتطف سجل التدقيق الأمني



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مقتطف سجل النظام والتدقيق الأمني

خادم الأنظمة الرقمية التعليمية، الفترة من 16-04-2026 إلى 17-04-2026

الطابع الزمني	نوع الحدث	الحساب أو الخدمة	المورد	قرار النظام	التفصيل
2026-04-16 08:14:22	مصادقة	حساب مدخل بيانات الخدمة	بوابة الوصول عن بُعد	نجاح	تم التحقق بكلمة مرور وعامل إضافي قبل إنشاء جلسة عمل.
2026-04-16 08:17:06	طلب وصول	حساب مدخل بيانات الخدمة	سجل التدقيق الأمني	مرفوض	قائمة التحكم في الوصول لا تمنح الدور أي تصريح على المورد.
2026-04-16 09:02:41	إنشاء طلب	حساب مدخل بيانات الخدمة	طلب تعديل صلاحيات المستخدمين	مقبول	أنشئ طلب لإضافة مستخدم جديد إلى دور مدخل بيانات الخدمة.
2026-04-16 10:11:33	اعتماد طلب	حساب مدير الخدمة	طلب تعديل صلاحيات المستخدمين	مقبول	اعتمد الطلب بعد مراجعة حاجة العمل، دون تنفيذ التغيير من الحساب المعتمد.
2026-04-16 10:26:18	تنفيذ تغيير	حساب مشغل النظام	طلب تعديل صلاحيات المستخدمين	مقبول	نُفذ التعيين للدور المحدد وسجل التغيير للمراجعة اللاحقة.
2026-04-17 08:30:09	مراجعة سجل	حساب مدقق الأمن	سجل التدقيق الأمني	مقبول	تمت قراءة أحداث اليوم السابق دون صلاحية تعديل أو حذف.

الرموز والسجلات المعروضة تعليمية ولا تتضمن بيانات تعريف شخصية أو بيانات تشغيلية فعلية.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ▶ يبدأ التسلسل في 2026-04-16 08:14:22 بمصادقة ناجحة لحساب مدخل بيانات الخدمة باستخدام كلمة مرور وعامل إضافي.
- ▶ بعد ذلك، عند 08:17:06، يرفض النظام طلب وصول الحساب إلى سجل التدقيق الأمني لغياب التصريح.
- ▶ ثم يسجل السجل إنشاء طلب تعديل الصلاحيات واعتماده وتنفيذه من ثلاثة أدوار منفصلة، بما يطبق فصل المهام.



- ◀ التحكم التقديري هو نموذج وصول يعتمد على المستخدم أو المجموعة وحقوق الكائن، ويكون للمالك دور في التحكم بالوصول.
- ◀ وظيفته تطبيق السماح أو المنع على الكائنات وفق قوائم أو تصاريح قابلة للإدارة، مثل DACL في Windows.
- ◀ **الوظيفة:** تطبيق الوصول وفق المالك والتصاريح.
- ◀ **المسؤوليات:** تحديد المالك، إسناد مسؤولية الكائن، إدارة DACL، ضبط قائمة السماح والمنع، ربط الجهات بالحقوق، تحديد مستخدم أو مجموعة، فحص ACE، تقييم مدخلات القائمة، مراجعة المشاركة، كشف التصاريح المتسعة.
- ▶ **البروتوكولات والمعايير:** AC-3(4) Discretionary Access Control, DACL, ACE, NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** DACL, ACE، تصاريح الملفات، مجموعات المستخدمين.
- ◀ **وحدة البيانات:** قرار وصول ناتج عن فحص قائمة DACL.
- ◀ **مثال:** يمنح مالك مجلد مجموعة محددة القراءة ويمنعها من الكتابة.



(الشكل) (Discretionary Access Control - DAC) التحكم التقديري

SLIDE 31 · DISCRETIONARY ACCESS CONTROL - DAC

التحكم التقديري

التحكم التقديري هو نموذج وصول يعتمد على المستخدم أو المجموعة، وحقوق الكائن، ويكون للمالك دور في التحكم بالوصول. وظيفته تطبيق السماح أو المنع على الكائنات وفق قوائم أو تصاريح قابلة للإدارة، مثل DACL في Windows.



الأجهزة والأدوات

- DACL
- ACE
- تصاريح الملفات
- مجموعات المستخدمين

البروتوكولات والمعايير

- AC-3(4) Discretionary Access Control
- DACL
- ACE
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- تطبيق الوصول وفق المالك والتصاريح
- تحديد المالك
- إسناد مسؤولية الكائن
- إدارة DACL
- ضبط قائمة السماح والمنع

يمنح مالك مجلد مجموعة محددة القراءة ويمنعها من الكتابة.

التحكم التقديري هو نموذج وصول يعتمد على المستخدم أو المجموعة وحقوق الكائن، ويكون للمالك دور في التحكم بالوصول.



- ◀ التحكم الإلزامي هو نموذج تفرض فيه سياسة مركزية إلزامية تستند إلى تسميات أو سمات أمنية للموضوعات والكائنات.
- ◀ وظيفته تقديم طبقة إضافية من العزل والضبط الدقيق فوق تصاريح DAC التقليدية، كما في SELinux.
- ◀ **الوظيفة:** فرض عزل مركزي قائم على السياسة.
- ◀ **المسؤوليات:** وضع التسميات، إسناد خصائص أمنية، تعريف السياسة، تحديد قواعد الوصول، فحص السياق الأمني، مقارنة الموضوع بالكائن، تقييد العمليات، منع الأفعال المخالفة، حماية الموارد والنظام من التجاوز، دعم العزل الدقيق.
- ▶ **البروتوكولات والمعايير:** AC-3(3) Mandatory Access Control, SELinux MAC, Security and Privacy Attributes AC-16.
- ◀ **الأجهزة:** SELinux، سياق SELinux، تسميات أمنية، سياسة MAC.
- ◀ **وحدة البيانات:** قرار وصول مستند إلى سياسة وتسمية أمنية.
- ◀ **مثال:** يسمح تطبيق بقراءة سجلات محددة ويمنع من تعديلها حتى مع اتساع بعض تصاريح DAC.



(الشكل) (Mandatory Access Control - MAC) التحكم الإلزامي

SLIDE 32 · MANDATORY ACCESS CONTROL - MAC

التحكم الإلزامي



الأجهزة والأدوات

- SELinux
- سياق SELinux
- تسميات أمنية
- سياسة MAC

البروتوكولات والمعايير

- AC-3(3) Mandatory Access Control
- SELinux MAC
- Security and Privacy Attributes AC-16

الوظائف الرئيسية

- فرض عزل مركزي قائم على السياسة
- وضع التسميات
- إسناد خصائص أمنية
- تعريف السياسة
- تحديد قواعد الوصول

يسمح تطبيق بقراءة سجلات محددة ويمنع من تعديلها حتى مع اتساع بعض تصاريح DAC

التحكم الإلزامي هو نموذج تفرض فيه سياسة مركزية إلزامية تستند إلى تسميات أو سمات أمنية للموضوعات والكائنات.



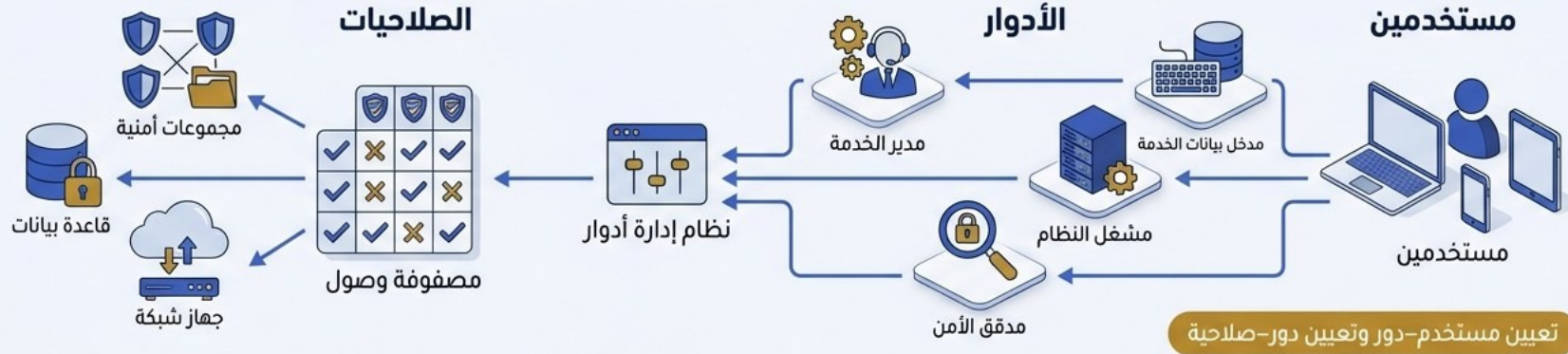
- ◀ التحكم المعتمد على الأدوار هو آلية توسط الوصول إلى الموارد عبر هويات تنظيمية تسمى الأدوار.
- ◀ وظيفته ربط الصلاحيات بالأدوار ثم تعيين المستخدمين للأدوار وفق المسؤوليات، بدلاً من إنشاء صلاحية مستقلة لكل مستخدم.
- ◀ **الوظيفة:** تنظيم الصلاحيات حسب الأدوار الوظيفية.
- ◀ **المسؤوليات:** تعريف الأدوار، تسمية المسؤوليات الوظيفية، تعيين المستخدمين، ربط الهوية بالدور، تعيين التصاريح للأدوار، توحيد حقوق العمل، ضبط هرمية الأدوار، تنظيم الوراثة، تطبيق قيود فصل المهام، منع تعارض الصلاحيات.
- ▶ **البروتوكولات والمعايير:** AC-3(7) Role-based Access Control, NIST RBAC, INCITS 359-2012 نموذج.
- ◀ **الأجهزة:** نظام إدارة أدوار، مجموعات أمنية، مصفوفة وصول، سجلات مراجعة.
- ◀ **وحدة البيانات:** تعيين مستخدم-دور وتعيين دور-صلاحية.
- ◀ **مثال:** تعيين الشركة أدوار مدخل بيانات الخدمة ومشغل النظام ومدقق الأمن ومدير الخدمة.



التحكم المعتمد على الأدوار (Role-Based Access Control - RBAC) (الشكل)

SLIDE 33 · ROLE-BASED ACCESS CONTROL - RBAC

التحكم المعتمد على الأدوار



الأجهزة والأدوات

- نظام إدارة أدوار
- مجموعات أمنية
- مصفوفة وصول
- سجلات مراجعة

البروتوكولات والمعايير

- AC-3(7) Role-based Access Control
- نموذج NIST RBAC
- INCITS 359-2012

الوظائف الرئيسية

- تنظيم الصلاحيات حسب الأدوار الوظيفية
- تعريف الأدوار
- تسمية المسؤوليات الوظيفية
- تعيين المستخدمين
- ربط الهوية بالدور

تعيين الشركة أدوار مدخل بيانات الخدمة ومشغل النظام ومدقق الأمن ومدير الخدمة

التحكم المعتمد على الأدوار هو آلية توسط الوصول إلى الموارد عبر هويات تنظيمية تسمى الأدوار



الفرق بين DAC و MAC و RBAC

وجه المقارنة	التحكم التقديرى (DAC)	التحكم الإلزامى (MAC)	التحكم المعتمد على الأدوار (RBAC)
مصدر قرار الوصول	المالك والتصاريح	سياسة مركزية وتسميات أمنية	الدور الوظيفي والصلاحيات المعينة
آلية الإسناد	ACE و DACL	سياق أمني وسياسة MAC	مستخدم إلى دور ثم دور إلى صلاحية
الاستخدام التعليمي	إدارة ملفات ومجلدات	عزل تطبيقات وموارد حساسة	توزيع صلاحيات العمل المؤسسي
مثال من الحالة	مالك مورد يمنح قراءة	SELinux يقيد فعل عملية	فصل إنشاء الطلب عن اعتماده وتنفيذه

تستخدم المقارنة لاختيار آلية مناسبة للمخاطر وطبيعة المورد.
لا يعد أي نموذج بديلاً متطابقاً للنماذج الأخرى في جميع البيئات.



- ◀ التسمية الأمنية هي علامة أو سياق أمني يرتبط بالعملية أو المورد لتمثيل خصائصه الأمنية عند تطبيق MAC.
- ◀ وظيفتها تمكين محرك السياسة من تقييم العلاقة بين الموضوع والكائن والفعل المطلوب، بدلاً من الاعتماد على اسم الملف أو مساره الظاهر فقط.
- ◀ **الوظيفة:** تمكين قرار MAC وفق خصائص أمنية.
- ◀ **المسؤوليات:** إسناد التسمية، ربط السياق بالكيان، المحافظة على اتساقها، منع اختلاف التصنيف، تفسيرها وفق السياسة، تطبيق قواعد الوصول، منع التعديل غير المصرح، حماية قيمة التسمية، مراجعة أخطاء التسمية، كشف عدم التطابق.
- ◀ **البروتوكولات والمعايير:** سياق SELinux, AC-16 Security and Privacy Attributes, AC-3(3) Mandatory Access Control.
- ◀ **الأجهزة:** SELinux، سياق SELinux، ملف، عملية، مورد نظام.
- ◀ **وحدة البيانات:** تسمية أو سياق أمني مرتبط بالكيان.
- ◀ **مثال:** يستخدم النظام سياق SELinux لتمييز عملية خادم وملف سجل ضمن سياسة وصول محددة.



التسمية الأمنية (Security Label) (الشكل)

SLIDE 35 · SECURITY LABEL

التسمية الأمنية

تسمية أو سياق أمني مرتبط بالكيان



الأجهزة والأدوات

- SELinux
- سياق SELinux
- ملف
- عملية
- مورد نظام

البروتوكولات والمعايير

- سياق SELinux
- AC-16 Security and Privacy Attributes
- AC-3(3) Mandatory Access Control

الوظائف الرئيسية

- تمكين قرار MAC وفق خصائص أمنية
- إسناد التسمية
- ربط السياق بالكيان
- المحافظة على اتساقها
- منع اختلاف التصنيف

يستخدم النظام سياق SELinux لتمييز عملية خادم وملف سجل ضمن سياسة وصول محددة.

التسمية الأمنية هي علامة أو سياق أمني يرتبط بالعملية أو المورد لتمثيل خصائصه الأمنية عند تطبيق MAC.



- ◀ الامتيازات هي حقوق أو قدرات تمنح جهات محددة تنفيذ وظائف إدارية أو حساسة في النظام.
- ◀ وظيفتها السماح بإدارة وظائف النظام مع تقييدها بالأدوار أو الحسابات المخولة، وبمراجعة وتدقيق استخدام هذه الوظائف.
- ◀ **الوظيفة:** إتاحة الوظائف الحساسة للجهات المخولة.
- ◀ **المسؤوليات:** تحديد الوظائف الحساسة، حصر الأفعال الإدارية، تقييد الوصول، قصر الحقوق على المخولين، فصل الحسابات الإدارية، منع الاستخدام اليومي المميز، مراجعة الاستخدام، فحص الحاجة المستمرة، تسجيل استخدام الوظائف المميزة، دعم المساءلة.
- ▶ **البروتوكولات والمعايير:** AC-3(1) Restricted Access to Privileged Functions, AC-6 Least Privilege, NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** حساب مميز، حقوق مستخدم Windows، مجموعات إدارية، سجلات تدقيق.
- ◀ **وحدة البيانات:** صلاحية مميزة أو قرار رفض أو سماح لوظيفة إدارية.
- ◀ **مثال:** يستخدم الحساب الإداري المنفصل لتغيير إعداد معتمد فقط.



الامتيازات (Privileges) (الشكل)

SLIDE 36 · PRIVILEGES

الامتيازات



الأجهزة والأدوات

- حساب مميز
- حقوق مستخدم Windows
- مجموعات إدارية
- سجلات تدقيق

البروتوكولات والمعايير

- AC-3(1) Restricted Access to Privileged Functions
- AC-6 Least Privilege
- NIST SP 800-53 Rev. 5

الوظائف الرئيسية

- إتاحة الوظائف الحساسة للجهات المخولة
- تحديد الوظائف الحساسة
- حصر الأفعال الإدارية
- تقييد الوصول
- قصر الحقوق على المخولين

يستخدم الحساب الإداري المنفصل لتغيير إعداد معتمد فقط.

الامتيازات هي حقوق أو قدرات تمنح جهات محددة تنفيذ وظائف إدارية أو حساسة في النظام.



(Privilege Escalation) تصعيد الامتيازات

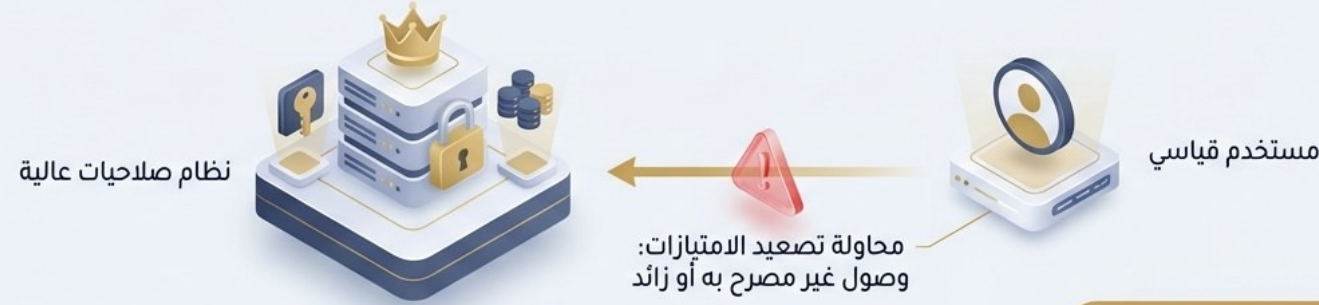
- ◀ تصعيد الامتيازات هو حصول مستخدم أو عملية على صلاحيات أعلى من الصلاحيات المصرح بها أو اللازمة.
- ◀ يمثل حالة خطر ينبغي منعها أو رصدها، وليس وظيفة تشغيلية يتعلم المتدرب تنفيذها.
- ◀ **الوظيفة:** مؤشر خطر يستدعي الوقاية والرصد.
- ◀ **المسؤوليات:** تقييد الوظائف المميزة، منع الوصول غير المصرح، مراجعة الامتيازات، كشف الحقوق الزائدة، مراقبة الاستخدام غير المعتاد، رصد النشاط المريب، تسجيل الأوامر أو الأحداث الحساسة، حفظ دليل المراجعة، تحديث الضوابط، معالجة سبب الخطر.
- ◀ **البروتوكولات والمعايير:** AC-2، AC-3، AC-6، AU-2، AU-6، AU-9 في NIST SP 800-53 Rev. 5.
- ◀ **الأجهزة:** مراجعة الحسابات، سجلات التدقيق، سياسات أقل الامتيازات، آليات MAC.
- ◀ **وحدة البيانات:** تنبيه أو سجل أو نتيجة مراجعة امتيازات.
- ◀ **مثال:** يسجل النظام محاولة تنفيذ وظيفة مميزة من حساب مستخدم قياسي لمراجعتها.



تصعيد الامتيازات (Privilege Escalation) (الشكل)

SLIDE 37 · PRIVILEGE ESCALATION

تصعيد الامتيازات



تنبيه أو سجل أو نتيجة مراجعة امتيازات.

الأجهزة والأدوات

- مراجعة الحسابات
- سجلات التدقيق
- سياسات أقل الامتيازات
- آليات MAC

البروتوكولات والمعايير

- AC-2
- AC-3
- AC-6
- AU-2
- AU-6

الوظائف الرئيسية

- مؤشر خطر يستدعي الوقاية والرصد
- تقييد الوظائف المميزة
- منع الوصول غير المصرح
- مراجعة الامتيازات
- كشف الحقوق الزائدة

يسجل النظام محاولة تنفيذ وظيفة مميزة من حساب مستخدم قياسي لمراجعتها.

تصعيد الامتيازات هو حصول مستخدم أو عملية على صلاحيات أعلى من الصلاحيات المصرح بها أو اللازمة.



حماية كلمة المرور (Password Protection)

- ◀ حماية كلمة المرور هي ضوابط حماية عامل المعرفة المستخدم في المصادقة، ضمن إدارة الهوية والحسابات ومحاولات الدخول.
- ◀ وظيفتها تقليل خطر انتحال الهوية والوصول غير المصرح به بالحسابات، ولا تعني أن كلمة المرور وحدها كافية لكل مورد حساس.
- ◀ **الوظيفة:** حماية عامل المعرفة في المصادقة.
- ◀ **المسؤوليات:** ضبط الحسابات، إدارة حالات الوصول، تقييد محاولات الدخول غير الناجحة، تقليل التخمين المتكرر، استخدام عوامل إضافية عند الحاجة، رفع موثوقية المصادقة، عدم مشاركة بيانات الدخول، حماية سرية الحساب، مراجعة الحسابات، كشف الحسابات غير اللازمة.
- ▶ **البروتوكولات والمعايير:** AC-2 Account Management, AC-7 Unsuccessful Logon Attempts, Identification and Authentication.
- ◀ **الأجهزة:** آلية تسجيل الدخول، سياسة كلمات المرور، قفل الحساب، سجل أحداث الأمن، MFA.
- ◀ **وحدة البيانات:** حالة تحقق من كلمة المرور أو حدث دخول ناجح أو فاشل.
- ◀ **مثال:** يقفل حساب تدريبي بعد تجاوز حد محاولات الدخول الفاشلة المعتمد في السياسة.



حماية كلمة المرور (Password Protection) (الشكل)

SLIDE 38 · PASSWORD PROTECTION

حماية كلمة المرور



الأجهزة والأدوات

- آلية تسجيل الدخول
- سياسة كلمات المرور
- قفل الحساب
- سجل أحداث الأمن
- MFA

البروتوكولات والمعايير

- AC-2 Account Management
- AC-7 Unsuccessful Logon Attempts
- Identification and Authentication عائلة

الوظائف الرئيسية

- حماية عامل المعرفة في المصادقة
- ضبط الحسابات
- إدارة حالات الوصول
- تقييد محاولات الدخول غير الناجحة
- تقليل التخمين المتكرر

يقفل حساب تدريبي بعد تجاوز حد محاولات الدخول الفاشلة المعتمد في السياسة.

حماية كلمة المرور هي ضوابط حماية عامل المعرفة المستخدم في المصادقة، ضمن إدارة الهوية والحسابات ومحاولات الدخول.



- ◀ المصادقة متعددة العوامل هي نظام مصادقة يتطلب أكثر من عامل متميز لنجاح المصادقة.
- ◀ وظيفتها زيادة الثقة في إثبات الهوية مقارنة بعامل واحد عندما تستدعي المخاطر ذلك، مثل الدخول عن بُعد أو تنفيذ إجراء إداري على مورد حساس.
- ◀ **الوظيفة:** رفع موثوقية إثبات الهوية.
- ◀ **المسؤوليات:** اختيار العوامل وفق المخاطر، موازنة الحماية والحاجة العملية، حماية عملية تسجيل الدخول، منع انتحال الهوية، إدارة الحسابات، ضبط الجهات المخولة، تسجيل النشاط المتعلق بالمصادقة، دعم التدقيق، مراجعة الاستثناءات، فحص الحالات غير الاعتيادية.
- ▶ **المعايير:** NIST SP 800-53 Rev. 5, Multi-Factor Authentication, Identification and Authentication.
- ◀ **الأجهزة:** كلمة مرور أو PIN، رمز أو جهاز تشفير، عامل حيوي، آلية تسجيل دخول.
- ◀ **وحدة البيانات:** نتيجة مصادقة ناجحة بعد تحقق عاملين أو أكثر.
- ◀ **مثال:** تتطلب سياسة الشركة MFA عند الدخول عن بُعد أو تنفيذ إجراء إداري على مورد حساس.



(Multi-Factor Authentication - MFA) المصادقة متعددة العوامل (الشكل)

SLIDE 39 · MULTI-FACTOR AUTHENTICATION - MFA

المصادقة متعددة العوامل



الأجهزة والأدوات

- كلمة مرور أو PIN
- رمز أو جهاز تشفير
- عامل حيوي
- آلية تسجيل دخول

البروتوكولات والمعايير

- NIST SP 800-53 Rev. 5
- Multi-Factor Authentication
- Identification and Authentication

الوظائف الرئيسية

- رفع موثوقية إثبات الهوية
- اختيار العوامل وفق المخاطر
- موازنة الحماية والحاجة العملية
- حماية عملية تسجيل الدخول
- منع انتحال الهوية

تتطلب سياسة الشركة MFA عند الدخول عن بُعد أو تنفيذ إجراء إداري على مورد حساس

المصادقة متعددة العوامل هي نظام مصادقة يتطلب أكثر من عامل متميز لنجاح المصادقة



الهدف الأمني	مثال من بيئة التشغيل	العامل المستخدم	فئة المصادقة
إثبات عامل المعرفة	إدخال كلمة مرور حساب الخدمة	كلمة مرور أو PIN	ما تعرفه
دعم عامل الحياة	عامل إضافي عند الدخول عن بُعد	رمز أو جهاز تشفير	ما تملكه
دعم عامل حيوي	تحقق حيوي عند توفره	عامل حيوي	ما تكونه
زيادة الثقة في الهوية	كلمة مرور وعامل إضافي	عاملان متميزان أو أكثر	MFA

تتحقق المصادقة متعددة العوامل من عوامل متميزة.
إدخال كلمة المرور مرتين لا يمثل عاملين مختلفين.



قراءة تقرير مراجعة الصلاحيات



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية

جازان، المملكة العربية السعودية

الرقم الضريبي: 3000000000000000 - السجل التجاري: 1010000000

هاتف: 0500000000

النموذج: تقرير مراجعة صلاحيات وحادثة انتهاك وصول

تاريخ المراجعة:

2026-04-17

الأصل محل المراجعة:

مجلد سجلات النظام الذي يحتفظ بسجل المصادقة وسجل التدقيق الأمني.

الجهة التي اكتشفت الحالة:

دور مدقق الأمن أثناء المراجعة الدورية للأذونات.

الحالة المكتشفة:

كانت مجموعة المستخدمين العامة تملك تصريح كتابة على مجلد سجلات النظام، رغم أن مهامها لا تتطلب قراءة السجلات أو تعديلها.

الأثر الأمني المحتمل:

قد يؤدي التصريح الزائد إلى تعديل أحداث السجل أو حذفها، مما يضعف سلامة التدقيق وقد يعيق التحقيق في محاولات الوصول غير المصرح بها.

السياسة أو المبدأ المتأثر:

مبدأ أقل الامتيازات، حماية سجلات التدقيق، وفصل واجبات تشغيل النظام عن مراجعة السجل.

الإجراء التصحيحي:

إزالة تصريح الكتابة من مجموعة المستخدمين العامة، وقصر كتابة السجلات على خدمة نظام التشغيل، ومنح مدقق الأمن قراءة فقط.

التحقق بعد المعالجة:

أثبت اختبار وصول لاحق أن حساب مدخل بيانات الخدمة تلقى قرار رفض عند محاولة الوصول إلى سجل التدقيق، بينما تمكن مدقق الأمن من القراءة فقط.

الإجراء الوقائي:

إضافة مراجعة ربع سنوية لقوائم التحكم في الوصول وتنبيه عند أي تغيير في أذونات مجلدات السجلات.

يرتبط التقرير بمصفوفة التحكم في الوصول ومقتطف سجل النظام، ويستخدم في تدريب الطالب على التحليل الدفاعي للصلاحيات المفرطة.

مقدم الطلب

المسؤول

الاعتماد

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ابدأ بقراءة تاريخ المراجعة 2026-04-17 وحدد الأصل، وهو مجلد سجلات النظام الذي يحتفظ بسجل المصادقة وسجل التدقيق الأمني.
- ثم اربط الحالة المكتشفة، وهي تصريح كتابة لمجموعة المستخدمين العامة، بالأثر المحتمل على سلامة السجلات.
- انتقل إلى الإجراء التصحيحي ونتيجة اختبار الوصول، ثم استخرج الإجراء الوقائي للمراجعة الدورية والتنبيه.

مثال محلول على النموذج، معالجة الصلاحيات المفرطة



شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

النموذج: تقرير مراجعة صلاحيات وحادثة انتهاك وصول

تاريخ المراجعة:

الأصل محل المراجعة:

الجهة التي اكتشفت الحالة:

الحالة المكتشفة:

الأثر الأمني المحتمل:

السياسة أو المبدأ المتأثر:

الإجراء التصحيحي:

التحقق بعد المعالجة:

الإجراء الوقائي:

يرتبط التقرير بمصفوفة التحكم في الوصول ومقتطف سجل النظام، ويستخدم في تدريب الطالب على التحليل الدفاعي للصلاحيات المفرطة.

مقدم الطلب

المسؤول

الاعتماد

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- المعطيات: بتاريخ 2026-04-17 اكتشف دور مدقق الأمن، أثناء المراجعة الدورية للأذونات، أن مجموعة المستخدمين العامة تملك تصريح كتابة على مجلد سجلات النظام.
- يحتفظ هذا المجلد بسجل المصادقة وسجل التدقيق الأمني، رغم أن مهام المجموعة لا تتطلب قراءة السجلات أو تعديلها.

الخطوة 1 من 3: توثيق حالة المراجعة والأصل



شركة الحلول التقنية والخدمات الرقمية

النموذج: تقرير مراجعة صلاحيات وحادثة انتهاك وصول

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

تاريخ المراجعة:

2026-04-17

الأصل محل المراجعة:

مجلد سجلات النظام الذي يحتفظ بسجل المصادقة وسجل التدقيق الأمني.

الجهة التي اكتشفت الحالة:

دور مدقق الأمن أثناء المراجعة الدورية للأذونات.

الحالة المكتشفة:

الأثر الأمني المحتمل:

السياسة أو المبدأ المتأثر:

الإجراء التصحيحي:

التحقق بعد المعالجة:

الإجراء الوقائي:

يرتبط التقرير بمصفوفة التحكم في الوصول ومقتطف سجل النظام، ويستخدم في تدريب الطالب على التحليل الدفاعي للصلاحيات المفرطة.

مقدم الطلب

المسؤول

الاعتماد

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يُدَوَّن تاريخ المراجعة 2026-04-17، ثم يحدد النموذج مجلد سجلات النظام أصلاً محل المراجعة لأنه يحتفظ بسجل المصادقة وسجل التدقيق الأمني.
- تسجل الجهة المكتشفة بوصفها دور مدقق الأمن أثناء المراجعة الدورية للأذونات.
- يثبت هذا التوثيق المورد والمسؤولية قبل تقييم التصريح المخالف.

الخطوة 2 من 3: تحليل التصريح المخالف وأثره

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

النموذج: تقرير مراجعة صلاحيات وحادثة انتهاك وصول

تقرير مراجعة صلاحيات وحادثة انتهاك وصول

تاريخ المراجعة: 2026-04-17

الأصل محل المراجعة: مجلد سجلات النظام الذي يحتفظ بسجل المصادقة وسجل التدقيق الأمني.

الجهة التي اكتشفت الحالة: دور مدقق الأمن أثناء المراجعة الدورية للأذونات.

الحالة المكتشفة: كانت مجموعة المستخدمين العامة تملك تصريح كتابة على مجلد سجلات النظام، رغم أن مهامها لا تتطلب قراءة السجلات أو تعديلها.

الأثر الأمني المحتمل: قد يؤدي التصريح الزائد إلى تعديل أحداث السجل أو حذفها، مما يضعف سلامة التدقيق وقد يعيق التحقيق في محاولات الوصول غير المصرح بها.

السياسة أو المبدأ المتأثر: مبدأ أقل الامتيازات، حماية سجلات التدقيق، وفصل واجبات تشغيل النظام عن مراجعة السجل.

الإجراء التصحيحي:

التحقق بعد المعالجة:

الإجراء الوقائي:

يرتبط التقرير بمصفوفة التحكم في الوصول ومقتطف سجل النظام، ويستخدم في تدريب الطالب على التحليل الدفاعي للصلاحيات المفرطة.

مقدم الطلب

المسؤول

الاعتماد

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يسجل النموذج تصريح الكتابة الممنوح لمجموعة المستخدمين العامة بوصفه الحالة المخالفة.
- لا تحتاج المجموعة إلى قراءة السجلات أو تعديلها، لذا يخرق الحق مبدأ أقل الامتيازات.
- قد يسمح التصريح بتعديل الأحداث أو حذفها، فيضعف سلامة التدقيق ويعيق التحقيق.
- يربط التحليل أيضاً بين حماية السجل وفصل واجبات تشغيل النظام عن مراجعته.



النموذج: تقرير مراجعة صلاحيات وحادثة انتهاك وصول

شركة الحلول التقنية والخدمات الرقمية

تقديم خدمات البنية التحتية والأنظمة الرقمية التعليمية
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

تقرير مراجعة صلاحيات وحادثة انتهاك وصول

تاريخ المراجعة: 2026-04-17

الأصل محل المراجعة: مجلد سجلات النظام الذي يحتفظ بسجل المصادقة وسجل التدقيق الأمني.

الجهة التي اكتشفت الحالة: دور مدقق الأمن أثناء المراجعة الدورية للأذونات.

الحالة المكتشفة: كانت مجموعة المستخدمين العامة تملك تصريح كتابة على مجلد سجلات النظام، رغم أن مهامها لا تتطلب قراءة السجلات أو تعديلها.

الأثر الأمني المحتمل: قد يؤدي التصريح الزائد إلى تعديل أحداث السجل أو حذفها، مما يضعف سلامة التدقيق وقد يعيق التحقيق في محاولات الوصول غير المصرح بها.

السياسة أو المبدأ المتأثر: مبدأ أقل الامتيازات، حماية سجلات التدقيق، وفصل واجبات تشغيل النظام عن مراجعة السجل.

الإجراء التصحيحي: إزالة تصريح الكتابة من مجموعة المستخدمين العامة، وقصر كتابة السجلات على خدمة نظام التشغيل، ومنح مدقق الأمن قراءة فقط.

التحقق بعد المعالجة: أثبت اختبار وصول لاحق أن حساب مدخل بيانات الخدمة تلقى قرار رفض عند محاولة الوصول إلى سجل التدقيق، بينما تمكن مدقق الأمن من القراءة فقط.

الإجراء الوقائي: إضافة مراجعة ربع سنوية لقوائم التحكم في الوصول وتنبيه عند أي تغيير في أذونات مجلدات السجلات.

يرتبط التقرير بمصفوفة التحكم في الوصول ومقتطف سجل النظام، ويستخدم في تدريب الطالب على التحليل الدفاعي للصلاحيات المفرطة.

الاعتماد

المسؤول

مقدم الطلب

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- الناتج: يزيل النموذج تصريح الكتابة من مجموعة المستخدمين العامة، ويقصر كتابة السجلات على خدمة نظام التشغيل، ويمنح مدقق الأمن قراءة فقط.
- يثبت اختبار الوصول اللاحق رفض حساب مدخل بيانات الخدمة عند طلب سجل التدقيق، مع استمرار قراءة المدقق فقط.
- تضاف مراجعة ربع سنوية وتنبيه لتغيير أذونات مجلدات السجلات.



جدول قرار مراجعة الصلاحيات

المورد	الحق السابق للمستخدمين العامة	الخطر	الحق بعد المعالجة	الجهة المخولة
مجلد سجلات النظام	كتابة	تعديل الأحداث أو حذفها	لا وصول	لا أحد من المستخدمين العامة
سجل المصادقة	وصول غير لازم	إضعاف سلامة المراجعة	كتابة مقيدة	خدمة نظام التشغيل
سجل التدقيق الأمني	كتابة محتملة	تعطيل التحقيق	قراءة فقط	مدقق الأمن
قوائم التحكم في الوصول	مراجعة غير منتظمة	تراكم صلاحيات	مراجعة كل ثلاثة أشهر	الجهة المسؤولة

يربط القرار بين المورد والحق والخطر والإجراء التصحيحي، ثم يثبت النتيجة باختبار وصول وسجل مراجعة.



نشاط تطبيقي 1، تحليل مصفوفة الوصول

المطلوب

١. حدد المبدأ الأمني الذي يطبقه هذا التوزيع.
٢. بين الخطر إذا امتلك دور واحد الإنشاء والاعتماد والتنفيذ.
٣. اقترح دوراً يقرأ الطلب للمراجعة دون تنفيذ التغيير.
٤. اكتب مبرراً من سطرين يربط اقتراحك بأقل الامتيازات.

السيناريو

تتضمن مصفوفة الشركة المورد «طلب تعديل صلاحيات المستخدمين».

يملك مدخل بيانات الخدمة إنشاء الطلب فقط، ويملك مدير الخدمة اعتماده فقط، وينفذ مشغل النظام التغيير بعد الاعتماد.

المطلوب:

أكمل النشاط قبل الانتقال إلى الشريحة التالية.



- ◀ يطبق التوزيع مبدأ فصل المهام، لأنه يفصل بين إنشاء طلب تعديل الصلاحيات واعتماده وتنفيذه.
- ◀ جمع هذه الأفعال في دور واحد يسمح بتغيير حساس دون مراجعة مستقلة ويزيد احتمال الخطأ أو إساءة الاستخدام.
- ◀ يمكن إسناد القراءة فقط إلى دور مدقق الأمن.
- ◀ لا يملك هذا الدور الإنشاء أو الاعتماد أو التنفيذ، لكنه يراجع السجل والطلب لاحقاً.
- ◀ يحقق ذلك أقل الامتيازات ويقوي المساءلة.



نشاط تطبيقي 2، تحليل سجل تدقيق



الوقت	الحدث	الحساب	القرار
08:14:22 2026-04-16	مصادقة	حساب مدخل بيانات الخدمة	نجاح
08:17:06 2026-04-16	طلب وصول إلى سجل التدقيق الأمني	حساب مدخل بيانات الخدمة	مرفوض
08:30:09 2026-04-17	مراجعة سجل	حساب مدقق الأمن	مقبول

اقرأ الأحداث الآتية من سجل التدقيق:
المطلوب: ميز بين حدث المصادقة وحدث التفويض، ثم فسر سبب رفض الوصول إلى سجل التدقيق الأمني، واقترح إجراء مراجعة وقائياً واحداً.



- المصادقة حدث إثبات هوية حساب مدخل بيانات الخدمة بنجاح عند 08:14:22. أما طلب الوصول عند 08:17:06 فهو قرار تفويض وتحكم في الوصول، وقد رفض لأن قائمة التحكم في الوصول لا تمنح هذا الدور تصريحاً على سجل التدقيق الأمني.
- يظهر حدث 2026-04-17 08:30:09 أن مدقق الأمن يقرأ السجل فقط.
- الإجراء الوقائي المناسب هو مراجعة تعيينات الأدوار وقوائم التحكم في الوصول كل ثلاثة أشهر وعند انتقال الموظف أو انتهاء مهمته.



- ◀ أضف إلى مشروعك التراكمي جدولاً أولياً لحماية بيئة التشغيل للخدمة المؤسسية التمثيلية.
- ◀ يجب أن يتضمن الجدول الأصول الحساسة، والأدوار، وحقوق الوصول، وقرار المصادقة، وآلية التدقيق.
- ◀ استخدم مبدأ أقل الامتيازات عند توزيع الحقوق.
- ◀ افصل بين دور إنشاء طلب تعديل الصلاحيات ودور اعتماده ودور تنفيذه.
- ◀ أضف قراراً واحداً يوضح كيف ستراجع قوائم التحكم في الوصول عند تغير مهمة أحد المستخدمين.
- ◀ مخرج المرحلة: صفحة واحدة ضمن حزمة المشروع تحتوي مصفوفة وصول وقرارين مبررين.



مرحلة المشروع التراكمي (تابع)

معيار القبول	متقن	نامٍ	غير متحقق
اكتمال المصفوفة	تشمل الأصول والأدوار والحقوق اللازمة	ينقصها عنصر محدود	تغفل أصولاً أو أدواراً جوهرية
دقة توزيع الحقوق	تطابق أقل الامتيازات وفصل المهام	يوجد حق زائد محدود	تجمع أفعالاً حساسة في دور واحد
تبرير القرارات	يربط القرار بالخطر والسجل أو السياسة	يقدم تبريراً عاماً	لا يقدم تبريراً عملياً
وضوح العرض	جدول منظم وقرارات قابلة للمراجعة	تنظيم مقبول مع نقص محدود	يصعب تتبع الحقوق والقرارات



شكل تعليمي، مسار الهوية إلى قرار الوصول والتدقيق



- ◀ يمثل المسار التعليمي طلب وصول يبدأ بموضوع، مثل حساب مدخل بيانات الخدمة، ثم تتحقق المصادقة من الهوية بكلمة مرور وعامل إضافي.
- ◀ بعد ذلك يفحص التفويض التصريح المطلوب على الكائن، مثل سجل التدقيق الأمني.
- ◀ ينفذ التحكم في الوصول قرار السماح أو الرفض، ثم يسجل التدقيق الحدث وقراره ليصبح قابلاً للمراجعة.
- ◀ يوضح المستند A3 نجاح المصادقة عند 08:14:22 ورفض الوصول عند 08:17:06.



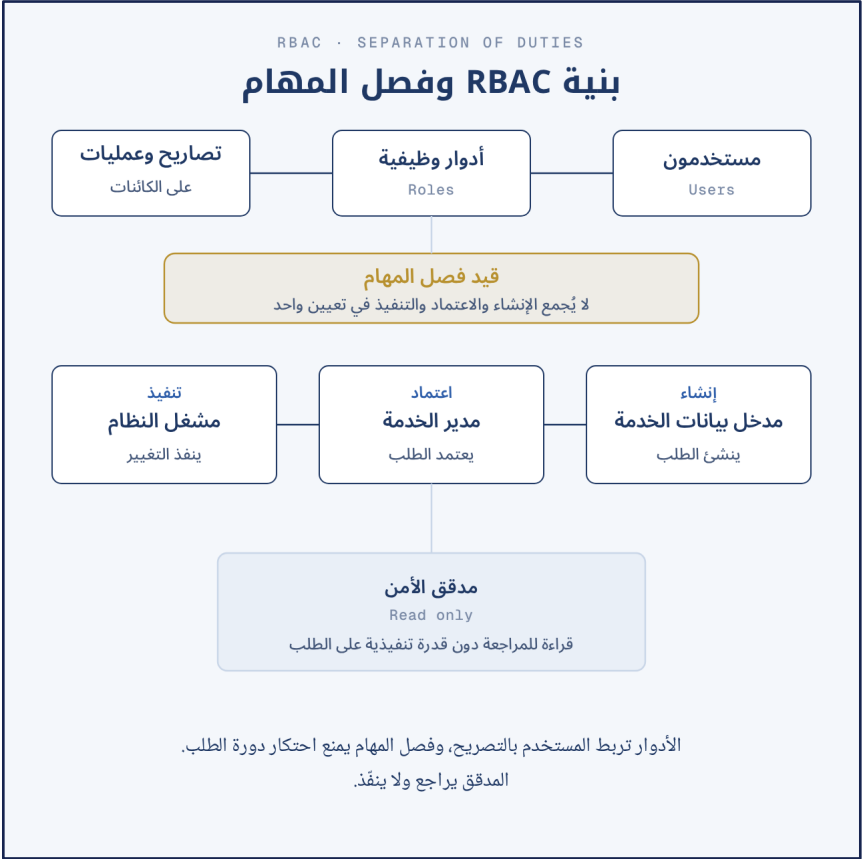
شكل تعليمي، مصفوفة الوصول وتحويلها إلى ACL



- تمثل صفوف مصفوفة الوصول الموضوعات أو الأدوار، وتمثل أعمدتها الكائنات المحمية، وتبين كل خلية الحق المسموح به.
- يساعد تحليل عمود واحد على إعداد قائمة التحكم في الوصول للكائن المقابل، بينما يكشف تحليل صف واحد الحقوق المتاحة لدور محدد.
- تستخدم المنشأة هذا التحليل قبل تنفيذ التصاريح، فتراجع حق مدقق الأمن في القراءة فقط لسجل التدقيق الأمني وتمنع الحقوق غير اللازمة.



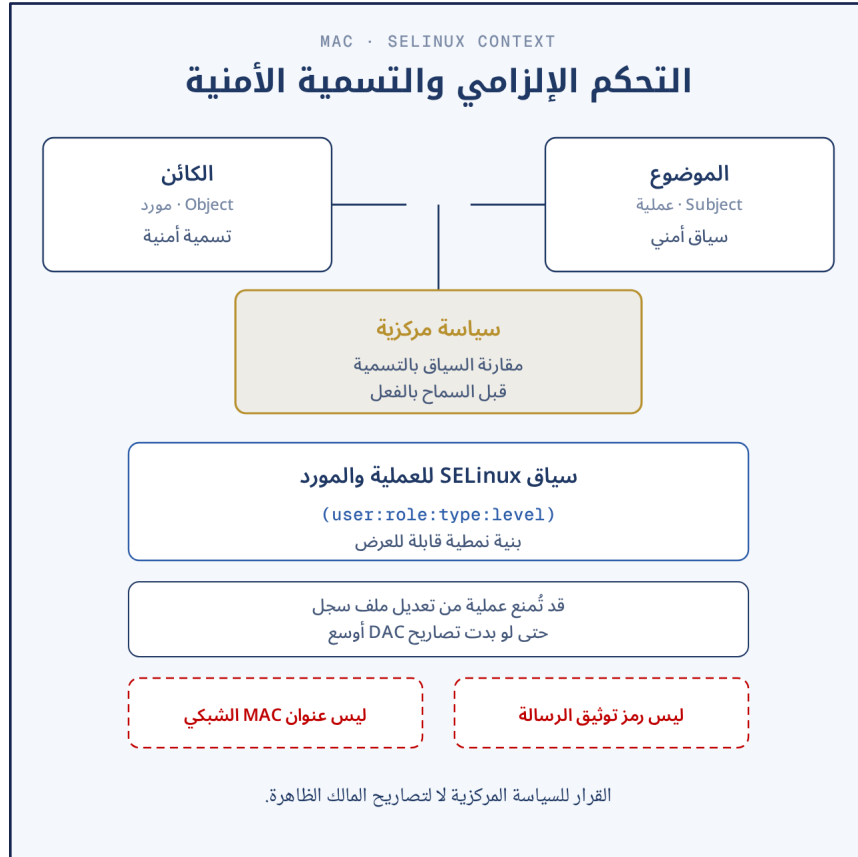
شكل تعليمي، بنية RBAC وفصل المهام



- ◀ يربط التحكم المعتمد على الأدوار المستخدمين بالأدوار الوظيفية، ثم يربط الأدوار بالتصاريح والعمليات على الكائنات.
- ◀ يمنع قيد فصل المهام جمع إنشاء طلب تعديل الصلاحيات واعتماده وتنفيذه في تعيين واحد.
- ◀ في الحالة المعروضة ينشئ مدخل بيانات الخدمة الطلب، ويعتمده مدير الخدمة، وينفذ مشغل النظام التغيير.
- ◀ يستطيع مدقق الأمن القراءة للمراجعة دون امتلاك قدرة تنفيذية على الطلب.



شكل تعليمي، التحكم الإلزامي والتسمية الأمنية



يفرض التحكم الإلزامي سياسة مركزية تقارن السياق الأمني للموضوع بالتسمية الأمنية للكائن قبل السماح بالفعل. في SELinux يحمل كل من العملية ومورد النظام سياقاً أمنياً، ويمكن عرض **بنية النمطية بصيغة (user:role:type:level)**. لذلك قد تمنع السياسة عملية من تعديل ملف سجل حتى لو بدا أن تصاريح DAC أوسع. يختلف هذا النموذج عن عنوان MAC الشبكي وعن رمز توثيق الرسالة.



✓ **الهدف الثاني:** تثبت المصادقة الهوية، بينما يقرر التفويض ما يسمح للهوية الموثقة بفعله على مورد محدد.

✓ **الهدف الأول:** يحمي أمن نظام التشغيل الأصول والحسابات والعمليات عبر سياسات وصول وتدقيق قابلة للمراجعة.

✓ **الهدف الرابع:** تكشف مصفوفة الوصول و ACL الحقوق الزائدة وتساعدان على ضبطها.

✓ **الهدف الثالث:** يختلف DAC و MAC و RBAC في مصدر قرار الوصول وآلية الإسناد والاستخدام المؤسسي.

✓ **الهدف الخامس:** تعالج الصلاحيات المفرطة بتطبيق أقل الامتيازات وفصل المهام وحماية سجلات التدقيق ومراجعتها.



المصادر الإلزامية: ◀

1. Silberschatz, A., Galvin, P. B., & Gagne, G. (2018). Operating System Concepts (10th ed.). Wiley.
2. Stallings, W. (2017). Operating Systems: Internals and Design Principles (9th ed.). Pearson.
3. Joint Task Force. (2020). Security and Privacy Controls for Information Systems and Organizations. NIST SP 800-53 Rev. 5.
4. Kent, K., & Souppaya, M. (2006). Guide to Computer Security Log Management. NIST SP 800-92.
5. Microsoft. Access control overview. Microsoft Learn.
6. Microsoft. Access Control Lists. Microsoft Learn.
7. Jansen, W. (1998). A Revised Model for Role Based Access Control. NIST IR 6192.
8. Red Hat. Using SELinux. Red Hat Enterprise Linux 8 System Design Guide.

◀ مصادر إضافية اختيارية: وثائق NIST و Microsoft Learn و Red Hat المرتبطة بالمفاهيم السابقة للتوسع والمراجعة الذاتية.



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان